



MCP Security Audit Report

AgentSign

notebooklm-mcp-cli

2 June 2026

Report ID: MCPS-MPW17HBK

Executive Summary

FAIL

Risk Score



10
CRITICAL

94
HIGH

373
MEDIUM

3
LOW

SCAN SCOPE 165 files 43,944 lines	LANGUAGES json (1), python (164)	MCPS SDK Not Found
---	-------------------------------------	-----------------------

Risk Comparison: WITHOUT MCPS vs WITH MCPS

CURRENT EXPOSURE			WITH MCPS PROTECTION		
MCP-01	Rug Pulls Vulnerable pattern detected, no mitigation	●	MITIGATED Passport identity binding — tools are tied to verified agent identity <code>createPassport()</code> , <code>signPassport()</code>		●
MCP-03	Privilege Escalation via Tool Composition Vulnerable pattern detected, no mitigation	●	MITIGATED Tool integrity signing — each tool definition is cryptographically signed <code>signTool()</code> , <code>verifyTool()</code>		●
MCP-04	Cross-Server Request Forgery Vulnerable pattern detected, no mitigation	●	MITIGATED Signed tool definitions prevent tampering during cross-server calls <code>signTool()</code> , <code>tool_hash</code>		●
MCP-06	Indirect Prompt Injection via MCP MCPS mitigation detected	●	MITIGATED Signed message envelopes — all MCP messages carry cryptographic signatures <code>signMessage()</code> , <code>verifyMessage()</code>		●
MCP-07	Resource Exhaustion & DoS MCPS mitigation detected	●	MITIGATED Passport verification middleware — all requests require valid signed identity <code>secureMCP()</code> , <code>verifyPassport()</code>		●
MCP-08	Insufficient Logging & Audit Vulnerable pattern detected, no mitigation	●	MITIGATED Signed audit trail — every message exchange is logged with cryptographic proof <code>auditLog()</code> , <code>onAudit()</code>		●
MCP-09	Insecure MCP-to-MCP Communication MCPS mitigation detected	●	MITIGATED Origin binding — passports encode allowed origins, verified on each request <code>validateOrigin()</code> , <code>passport.origin</code>		●
MCP-10	Context Window Pollution MCPS mitigation detected	●	MITIGATED Envelope isolation — signed message boundaries prevent context pollution <code>signMessage()</code> , <code>envelope</code>		●
Risk Reduction					
100 --> 100					

OWASP MCP Top 10 Compliance

Coverage: 4/8 risks mitigated by MCPS

ID	Risk	Status	Current State	With MCPS
MCP-01	Rug Pulls	FAIL	Vulnerable pattern detected, no mitigation	Passport identity binding — tools are tied to verified agent identity
MCP-02	Tool Poisoning	N/A	Not applicable to code-level analysis	N/A — requires LLM-level defense
MCP-03	Privilege Escalation via Tool Composition	FAIL	Vulnerable pattern detected, no mitigation	Tool integrity signing — each tool definition is cryptographically signed
MCP-04	Cross-Server Request Forgery	FAIL	Vulnerable pattern detected, no mitigation	Signed tool definitions prevent tampering during cross-server calls
MCP-05	Sampling Manipulation	N/A	Not applicable to code-level analysis	N/A — requires client-level defense
MCP-06	Indirect Prompt Injection via MCP	PASS	MCPS mitigation detected	Signed message envelopes — all MCP messages carry cryptographic signatures
MCP-07	Resource Exhaustion & DoS	PASS	MCPS mitigation detected	Passport verification middleware — all requests require valid signed identity
MCP-08	Insufficient Logging & Audit	FAIL	Vulnerable pattern detected, no mitigation	Signed audit trail — every message exchange is logged with cryptographic proof
MCP-09	Insecure MCP-to-MCP Communication	PASS	MCPS mitigation detected	Origin binding — passports encode allowed origins, verified on each request
MCP-10	Context Window Pollution	PASS	MCPS mitigation detected	Envelope isolation — signed message boundaries prevent context pollution

Quick Fix `npm install mcp-secure`

Add MCPS to your MCP server to automatically mitigate the risks marked FAIL above.

OWASP Agentic AI Top 10 Coverage

12 rules checked | 480 findings

Rule	OWASP	MITRE	STRIDE	Severity	Findings	Status
AS-001	AA-03	T1059	Elevation of Privilege	CRITICAL	7	
AS-002	AA-05	T1552	Information Disclosure	HIGH	13	
AS-003	AA-04	T1078	Elevation of Privilege	MEDIUM	230	
AS-004	AA-02	T1190	Tampering	HIGH	19	
AS-005	AA-02	T1055	Tampering	CRITICAL	3	
AS-006	AA-09	T1610	Elevation of Privilege	HIGH	1	
AS-007	AA-06	T1195	Tampering	LOW	3	
AS-008	AA-01	T1548	Elevation of Privilege	HIGH	33	
AS-009	AA-07	T1059.007	Tampering	MEDIUM	0	
AS-010	AA-08	T1562.002	Repudiation	MEDIUM	143	
AS-011	AA-10	T1041	Information Disclosure	HIGH	28	
AS-012	MCP-07	T1078.004	Spoofing	HIGH	0	

Detailed Findings

#1 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[desktop-extension/run_server.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
   2 | """Robust launcher for NotebookLM MCP Server in Claude Desktop...
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#2 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[scripts/build_mcpb.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
   2 | """Build the .mcpb extension package for Claude Desktop.
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#3 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[scripts/inject_cookies_and_inspect.py:107](#)

Dangerous execution: (async function) {

```
105 |         {
106 |             "expression": ""
> 107 |         (async function() {
108 |             function sleep(ms) { return new Promise(resolve => setTimeout(resolve, ms)); }
109 |
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#4 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[scripts/inject_cookies_and_inspect.py:158](#)

Dangerous execution: (async function() {

```
156 |           {
157 |             "expression": ""
> 158 |           (async function() {
159 |             function sleep(ms) { return new Promise(resolve => setTimeout(resolve, ms)); }...
160 |           }
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#5 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[scripts/inspect_upload_dom.py:104](#)

Dangerous execution: (function() {

```
102 |           {
103 |             "expression": ""
> 104 |           (function() {
105 |             const walker = document.createTreeWalker(document.body, NodeFilter.SHOW_TEXT);
106 |             const matches = [];
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#6 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[scripts/inspect_upload_dom.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """
2 |   Script to inspect NotebookLM DOM for file upload selectors.
3 |   """
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#7 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[scripts/test_label_rpc.py:48](#)

High-risk permission pattern: RPC_LABEL_DELETE = "GyzE7e" # delete one or many labels

```
46 |     RPC_LABEL_MANAGE = "agX4Bc" # auto-label + create + list
47 |     RPC_LABEL_MUTATE = "le8sX"  # rename + emoji + move source
> 48 |     RPC_LABEL_DELETE = "GyzE7e" # delete one or many labels
49 |     RPC_USER_TIER = "ozz5Z"    # get subscription tier (fires on page load)
50 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#8 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[scripts/test_label_rpc.py:100](#)

High-risk permission pattern: `"""Delete one or more labels (sources are preserved)."""`

```
98 |  
> 99 |     def delete_labels(self, notebook_id: str, label_ids: list[str]) -> bool:  
100 |         """Delete one or more labels (sources are preserved)."""  
101 |         params = [[2], notebook_id, label_ids]...  
102 |         result = self._call_rpc(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#9 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[scripts/test_label_rpc.py:205](#)

High-risk permission pattern: `section("6. DELETE LABEL (cleanup)")`

```
203 |         print(" (skipped – need 2+ labels and at least 1 source)")  
204 |  
> 205 |         section("6. DELETE LABEL (cleanup)")  
206 |         if created_label_id:  
207 |             try:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#10 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[scripts/test_label_rpc.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3  
2 | """POC test script for label management RPCs.  
3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#11 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """NotebookLM Tools - Unified CLI and MCP server for Google NotebookLM."""
  2 | ...
  3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#12 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """CLI interface for NotebookLM."""
  2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#13 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:90](#)

High-risk permission pattern: | `nlm auth` | Check authentication status (status, list, delete) |

```
88 | |-----|-----|
89 | | `nlm login` | Authenticate with NotebookLM (**START HERE**) |
> 90 | | `nlm auth` | Check authentication status (status, list, delete) |
91 | | `nlm config` | View/edit configuration (show, get, set) |
92 | | `nlm notebook` | Manage notebooks (list, create, get, describe, rename, delete, query) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#14 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:92](#)

High-risk permission pattern: | `nlm notebook` | Manage notebooks (list, create, get, describe, rename, delete

```
90 | | `nlm auth` | Check authentication status (status, list, delete) |
91 | | `nlm config` | View/edit configuration (show, get, set) |
> 92 | | `nlm notebook` | Manage notebooks (list, create, get, describe, rename, delete, query) |
93 | | `nlm source` | Manage sources (list, add, get, describe, content, rename, delete, stale, sync) |
94 | | `nlm chat` | Chat with notebooks (start, configure) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#15 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:93](#)

High-risk permission pattern: | `nlm source` | Manage sources (list, add, get, describe, content, rename, delete)

```
91 | | `nlm config` | View/edit configuration (show, get, set) |
92 | | `nlm notebook` | Manage notebooks (list, create, get, describe, rename, delete, query) |
> 93 | | `nlm source` | Manage sources (list, add, get, describe, content, rename, delete, stale, sync) |
94 | | `nlm chat` | Chat with notebooks (start, configure) |...
95 | | `nlm studio` | Manage artifacts (status, delete) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#16 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:95](#)

High-risk permission pattern: | `nlm studio` | Manage artifacts (status, delete) |

```
93 | | `nlm source` | Manage sources (list, add, get, describe, content, rename, delete, stale, sync) |
94 | | `nlm chat` | Chat with notebooks (start, configure) |
> 95 | | `nlm studio` | Manage artifacts (status, delete) |
96 | | `nlm research` | Research and discover sources (start, status, import) |
97 | | `nlm alias` | Manage ID shortcuts (set, get, list, delete) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#17 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:97](#)

High-risk permission pattern: | `nlm alias` | Manage ID shortcuts (set, get, list, delete) |

```
95 | | `nlm studio` | Manage artifacts (status, delete) |
96 | | `nlm research` | Research and discover sources (start, status, import) |
> 97 | | `nlm alias` | Manage ID shortcuts (set, get, list, delete) |
98 | | `nlm download` | Download artifacts (audio, video, report, mind-map, slides, infographic, data-
table) |
99 | | `nlm audio` | Create audio overviews/podcasts (create) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#18 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:109](#)

High-risk permission pattern: | `nlm batch` | Batch operations across multiple notebooks (query, add-source, create, delete)

```
107 | | `nlm data-table` | Create data tables (create) |
108 | | `nlm share` | Manage notebook sharing (status, public, private, invite) |
> 109 | | `nlm batch` | Batch operations across multiple notebooks (query, add-source, create, delete,
studio) |
110 | | `nlm cross` | Cross-notebook aggregated query (query) |
111 | | `nlm pipeline` | Multi-step notebook workflows (list, run) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#19 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:124](#)

High-risk permission pattern: | `nlm delete` | Delete resources (notebook, source, artifact, alias) |

```
122 | | `nlm list` | List resources (notebooks, sources, artifacts, aliases, stale-sources) |
123 | | `nlm get` | Get details (notebook, source, config, alias) |
> 124 | | `nlm delete` | Delete resources (notebook, source, artifact, alias) |
125 | | `nlm add` | Add sources (url, text, drive) |...
126 | | `nlm describe` | Get AI summaries (notebook, source) |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#20 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:160](#)

High-risk permission pattern: nlm alias delete myproject # Remove

```
158 | nlm alias list # List all
159 | nlm alias get myproject # Resolve to UUID
> 160 | nlm alias delete myproject # Remove
161 | ``
162 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#21 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:179](#)

High-risk permission pattern: nlm auth delete work --confirm # Delete a profile

```
177 | nlm auth status --profile work # Check specific profile
178 | nlm auth list # List all profiles
> 179 | nlm auth delete work --confirm # Delete a profile
180 | ``
181 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#22 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:198](#)

High-risk permission pattern: `nlm notebook delete <id> --confirm` # Delete permanently

```
196 | nlm notebook describe <id> --json      # JSON output
197 | nlm notebook rename <id> "New Title"    # Rename notebook
> 198 | nlm notebook delete <id> --confirm    # Delete permanently
199 | nlm notebook query <id> "question"      # Chat with sources...
200 | nlm notebook query <id> "question" --json # JSON output
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#23 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:212](#)

High-risk permission pattern: `nlm delete notebook <id> --confirm` # Delete permanently

```
210 | nlm describe notebook <id>              # AI summary with topics
211 | nlm rename notebook <id> "New Title"     # Rename notebook
> 212 | nlm delete notebook <id> --confirm    # Delete permanently
213 | nlm query notebook <id> "question"      # Chat with sources
214 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#24 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:245](#)

High-risk permission pattern: `nlm source delete <source-id> --confirm` # Delete source

```
243 | nlm source content <source-id> --output file.txt # Export to file
244 | nlm source rename <source-id> "New Title" --notebook <notebook-id> # Rename source
> 245 | nlm source delete <source-id> --confirm    # Delete source
246 | nlm source stale <notebook-id>                # List stale Drive sources
247 | nlm source sync <notebook-id> --confirm        # Sync all stale
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#25 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:263](#)

High-risk permission pattern: `nlm delete source <source-id> --confirm` # Delete source

```
261 | nlm content source <source-id>           # Raw text content
262 | nlm rename source <source-id> "New Title" --notebook <notebook-id> # Rename source
> 263 | nlm delete source <source-id> --confirm    # Delete source
264 | nlm list stale-sources <notebook-id>       # List stale Drive sources
265 | nlm stale sources <notebook-id>           # Alternative: list stale sources
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#26 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:496](#)

High-risk permission pattern: `nlm studio delete <notebook-id> <artifact-id> --confirm` # Delete artifact

```
494 | nlm studio status <notebook-id> --json          # JSON output
495 | nlm studio status <notebook-id> --full         # All details
> 496 | nlm studio delete <notebook-id> <artifact-id> --confirm # Delete artifact
497 | nlm slides revise <artifact-id> --slide '1 instruction' --confirm # Revise slides...
498 | ```
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#27 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:504](#)

High-risk permission pattern: `nlm delete artifact <notebook-id> <artifact-id> --confirm` # Delete artifact

```
502 | nlm status artifacts <notebook-id>              # List all artifacts + status
503 | nlm status artifacts <notebook-id> --full       # All details
> 504 | nlm delete artifact <notebook-id> <artifact-id> --confirm # Delete artifact
505 | ```
506 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#28 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:577](#)

High-risk permission pattern: `nlm alias delete <name>` # Remove (no --confirm needed)

```
575 | nlm alias get <name>          # Get UUID for alias
576 | nlm alias list              # List all aliases
> 577 | nlm alias delete <name>    # Remove (no --confirm needed)
578 | ```
579 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#29 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:586](#)

High-risk permission pattern: `nlm delete alias <name>` # Remove alias

```
584 | nlm list aliases          # List all aliases
585 | nlm show aliases         # Alternative: show all aliases
> 586 | nlm delete alias <name> # Remove alias
587 | ``...
588 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#30 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:622](#)

High-risk permission pattern: `nlm batch delete --notebooks "id1,id2" --confirm`

```
620 |
621 | nlm batch create "Project A, Project B, Project C" # Create multiple
> 622 | nlm batch delete --notebooks "id1,id2" --confirm
623 | nlm batch studio --type audio --tags "research" --confirm
624 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#31 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:957](#)

High-risk permission pattern: 2. `**Use `--confirm` for all generation/delete commands**` to avoid blocking prom

```
955 |
956 | 1. **Always run `nlm login` first** if any auth error occurs
> 957 | 2. **Use `--confirm` for all generation/delete commands** to avoid blocking prompts
958 | 3. **Capture IDs from create outputs** - you'll need them for subsequent operations
959 | 4. **Use aliases** for frequently-used notebooks to simplify commands
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#32 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:964](#)

High-risk permission pattern: 9. `**& p ALWAYS ask user before delete**` - Before running ANY delete command, ask

```
962 | 7. **Session lifetime is ~20 minutes** - re-login if operations start failing
963 | 8. **Use `--max-wait 0`** for single status poll instead of blocking
> 964 | 9. **& p ALWAYS ask user before delete** - Before running ANY delete command, ask the user for explicit
confirmation. Deletions are IRREVERSIBLE. Show what will be deleted and warn about permanent data loss.
965 | 10. **Check aliases before creating** - Run `nlm alias list` or `nlm list aliases` before creating a
new alias to avoid conflicts with existing names.
966 | 11. **DO NOT launch REPL** - Never use `nlm chat start` - it opens an interactive REPL that AI tools
cannot control. Use `nlm notebook query` or `nlm query notebook` for one-shot Q&A instead.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#33 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/ai_docs.py:968](#)

High-risk permission pattern: 13. **Verb-first vs Noun-first**** - Both command styles work identically. Use whi**

```
966 | 11. **DO NOT launch REPL** - Never use `nlm chat start` - it opens an interactive REPL that AI tools
cannot control. Use `nlm notebook query` or `nlm query notebook` for one-shot Q&A instead.
967 | 12. **Choose output format wisely** - Default output (no flags) is compact and token-efficient—use
it for status checks. Use `--quiet` to capture IDs for piping. Only use `--json` when you need to parse
specific fields programmatically.
> 968 | 13. **Verb-first vs Noun-first** - Both command styles work identically. Use whichever is more
natural for the context. Noun-first groups by resource (notebook, source), verb-first groups by action
(create, list, delete).
969 | 14. **Download workflow** - Always wait for artifact completion before downloading. Check status
with `nlm studio status <notebook>`, get the artifact ID, then download with `nlm download <type> <notebook>
<artifact-id>`.
970 | 15. **Artifact generation takes time** - Audio/video: 1-5 minutes. Reports/quizzes: 30-60 seconds.
Always poll status before attempting download.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#34 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/ai_docs.py:334](#)

Unrestricted agent autonomy: - `--confirm` or `-y`: Skip confirmation (REQUIRED for automation)

```
332 |
333 | **All generation commands support:**
> 334 | - `--confirm` or `-y`: Skip confirmation (REQUIRED for automation)
335 | - `--source-ids <id1,id2>`: Limit to specific sources
336 | - `--language <code>`: BCP-47 code (en, es, fr, de, ja)
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#35 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/ai_docs.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """AI-friendly documentation output for the --ai flag."""
2 |
3 | from notebooklm_tools import __version__
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#36 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """CLI command implementations."""...
  2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#37 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/alias.py:89](#)

High-risk permission pattern: @app.command("delete")

```
87 |
88 |
> 89 | @app.command("delete")
  90 | def delete_alias(
  91 |     name: str = typer.Argument(..., help="Alias name"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#38 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/alias.py:94](#)

High-risk permission pattern: """Delete an alias."""

```
92 |         confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
93 |     ) -> None:
> 94 |         """Delete an alias."""
  95 |         if not confirm:
  96 |             typer.confirm(f"Are you sure you want to delete alias '{name}'?", abort=True)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#39 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/alias.py:96](#)

High-risk permission pattern: typer.confirm(f"Are you sure you want to delete alias '{name}'?", abort=True)

```
94 |         """Delete an alias."""
95 |         if not confirm:
> 96 |             typer.confirm(f"Are you sure you want to delete alias '{name}'?", abort=True)
  97 |
  98 |         manager = get_alias_manager()
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#40 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/alias.py:92](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
90 | def delete_alias(  
91 |     name: str = typer.Argument(..., help="Alias name"),  
> 92 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),  
93 | ) -> None: ...  
94 |     """Delete an alias."""
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#41 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/alias.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Alias CLI commands."""  
2 |  
3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#42 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/batch.py:111](#)

High-risk permission pattern: @app.command("delete")

```
109 |  
110 |  
> 111 | @app.command("delete")  
112 | def batch_delete(  
113 |     notebooks: str | None = typer.Option(  
114 |         None,  
115 |         help="Notebooks to delete, separated by commas",  
116 |     ),  
117 | ) -> None:  
118 |     """Delete multiple notebooks. IRREVERSIBLE."""  
119 |     from notebooklm_tools.cli.utils import get_client  
120 |     from notebooklm_tools.services import batch as batch_service  
121 |     client = get_client()  
122 |     notebooks_list = notebooks.split(",") if notebooks else []  
123 |     batch_service.delete_notebooks(client, notebooks_list)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#43 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/batch.py:119](#)

High-risk permission pattern: """Delete multiple notebooks. IRREVERSIBLE."""

```
117 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Confirm deletion"),  
118 | ) -> None:  
> 119 |     """Delete multiple notebooks. IRREVERSIBLE."""  
120 |     from notebooklm_tools.cli.utils import get_client  
121 |     from notebooklm_tools.services import batch as batch_service  
122 |     client = get_client()  
123 |     notebooks_list = notebooks.split(",") if notebooks else []  
124 |     batch_service.delete_notebooks(client, notebooks_list)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#44 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/batch.py:124](#)

High-risk permission pattern: typer.confirm("This will PERMANENTLY delete multiple notebooks. Continue?", abort

```
122 |  
123 |     if not confirm:  
> 124 |         typer.confirm("This will PERMANENTLY delete multiple notebooks. Continue?", abort=True)  
125 |         confirm = True...  
126 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#45 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/batch.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Batch CLI commands – perform operations across multiple notebooks."""  
2 |  
3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#46 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/chat.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Chat configuration CLI commands."""  
2 |  
3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#47 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/config.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Configuration CLI commands."""
  2 | ...
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#48 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/cross.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Cross-notebook CLI commands – query across multiple notebooks."""
  2 |
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#49 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/notebooklm_tools/cli/commands/doctor.py:325](#)

Dangerous execution: result = subprocess.run(# nsec B603 — cmd from shutil.which(), args are hardc

```
323 |         if claude_cmd:
324 |             try:
> 325 |                 result = subprocess.run( # nsec B603 – cmd from shutil.which(), args are
hardcoded strings, no shell=True
326 |                                     [claude_cmd, "mcp", "list"],
327 |                                     capture_output=True,
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#50 AS-006 -- SANDBOXING

HIGH

OWASP: AA-09 | MITRE: T1610 | STRIDE: Elevation of Privilege

Code execution without sandboxing or isolation mechanisms

[src/notebooklm_tools/cli/commands/doctor.py:325](#)

Code execution without sandboxing

```
323 |         if claude_cmd:
324 |             try:
> 325 |                 result = subprocess.run( # nsec B603 – cmd from shutil.which(), args are
hardcoded strings, no shell=True
326 |                                     [claude_cmd, "mcp", "list"],
327 |                                     capture_output=True,
```

Remediation:

1. Run all agent-generated code in Docker containers with `--network=none` and read-only filesystem. 2. Use gVisor/Firecracker for stronger isolation. 3. Set resource limits (CPU, memory, time) on execution. 4. Use E2B or Modal for managed sandboxed execution. 5. Never execute agent code in the host process.

MCPS Quick Fix: `npm install mcp-secure`

#51 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/notebooklm_tools/cli/commands/doctor.py:1`

No logging, auditing, or monitoring detected

```
> 1 | """Diagnostic command for troubleshooting NotebookLM MCP setup."""
  2 | ...
  3 | import platform
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#52 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/notebooklm_tools/cli/commands/download.py:1`

No logging, auditing, or monitoring detected

```
> 1 | """Download CLI commands."""
  2 |
  3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#53 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`src/notebooklm_tools/cli/commands/export.py:1`

No logging, auditing, or monitoring detected

```
> 1 | """Export CLI commands - Export artifacts to Google Docs/Sheets."""
  2 |
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#54 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/label.py:235](#)

High-risk permission pattern: `@app.command("delete")`

```
233 |  
234 |  
> 235 | @app.command("delete")  
236 | def delete_label(...  
237 |     notebook_id: str = typer.Argument(..., help="Notebook ID or alias"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#55 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/label.py:238](#)

High-risk permission pattern: `label_id: str = typer.Argument(..., help="Label UUID to delete")`,

```
236 | def delete_label(  
237 |     notebook_id: str = typer.Argument(..., help="Notebook ID or alias"),  
> 238 |     label_id: str = typer.Argument(..., help="Label UUID to delete"),  
239 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Confirm deletion without prompt"),  
240 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#56 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/label.py:243](#)

High-risk permission pattern: `"""Delete a label permanently. Sources are NOT deleted."""`

```
241 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),  
242 | ) -> None:  
> 243 |     """Delete a label permanently. Sources are NOT deleted."""  
244 |     if not confirm:  
245 |         confirmed = typer.confirm(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#57 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/label.py:246](#)

High-risk permission pattern: `f"Delete label {label_id[:8]}...? Sources will be preserved."`,

```
244 |     if not confirm:  
245 |         confirmed = typer.confirm(  
> 246 |             f"Delete label {label_id[:8]}...? Sources will be preserved.",  
247 |             default=False,  
248 |         )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#58 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/label.py:102](#)

Unrestricted agent autonomy: False, "--confirm", "-y", help="Skip confirmation prompt (all-sources mode)"

```
100 |     ),
101 |     confirm: bool = typer.Option(
102 |         False, "--confirm", "-y", help="Skip confirmation prompt (all-sources mode)"
103 |     ), ...
104 |     json_output: bool = typer.Option(False, "--json", "-j", help="Output as JSON"),
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#59 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/label.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Label CLI commands - manage source labels in a notebook."""
  2 |
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#60 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/note.py:105](#)

High-risk permission pattern: @app.command("delete")

```
103 |
104 |
> 105 | @app.command("delete")
    106 | def delete_note(
    107 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#61 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/note.py:108](#)

High-risk permission pattern: `note_id: str = typer.Argument(..., help="Note ID to delete")`,

```
106 | def delete_note(  
107 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),  
> 108 |     note_id: str = typer.Argument(..., help="Note ID to delete"),  
109 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),...  
110 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#62 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/note.py:112](#)

High-risk permission pattern: `"""Delete a note permanently."""`

```
110 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),  
111 | ) -> None:  
> 112 |     """Delete a note permanently."""  
113 |     if not confirm:  
114 |         confirmed = typer.confirm(f"Delete note {note_id}? This action is IRREVERSIBLE.")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#63 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/note.py:114](#)

High-risk permission pattern: `confirmed = typer.confirm(f"Delete note {note_id}? This action is IRREVERSIBLE.")`

```
112 |     """Delete a note permanently."""  
113 |     if not confirm:  
> 114 |         confirmed = typer.confirm(f"Delete note {note_id}? This action is IRREVERSIBLE.")  
115 |         if not confirmed:  
116 |             console.print("[dim]Cancelled[/dim]")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#64 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/note.py:109](#)

Unrestricted agent autonomy: `confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")`

```
107 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),  
108 |     note_id: str = typer.Argument(..., help="Note ID to delete"),  
> 109 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),  
110 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),  
111 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#65 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/note.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Note CLI commands."""
  2 | ...
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#66 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/notebook.py:118](#)

High-risk permission pattern: `@app.command("delete")`

```
116 |
117 |
> 118 | @app.command("delete")
    119 | def delete_notebook(
    120 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#67 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/notebook.py:124](#)

High-risk permission pattern: `"""Delete a notebook permanently."""`

```
122 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
123 | ) -> None:
> 124 |     """Delete a notebook permanently."""
    125 |     notebook_id = get_alias_manager().resolve(notebook_id)
    126 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#68 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/notebook.py:129](#)

High-risk permission pattern: `f"Are you sure you want to delete notebook {notebook_id}?"`,

```
127 |         if not confirm:
128 |             typer.confirm(
> 129 |                 f"Are you sure you want to delete notebook {notebook_id}?",
130 |                 abort=True,...
131 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#69 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/notebook.py:121](#)

Unrestricted agent autonomy: `confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")`

```
119 | def delete_notebook(
120 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
> 121 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
122 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
123 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#70 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/notebook.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Notebook CLI commands."""
  2 |
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, `timestamp`, `action`, `parameters`, and `outcome` in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#71 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/pipeline.py:1](#)

High-risk permission pattern: `"""Pipeline CLI commands — define and execute multi-step workflows."""`

```
> 1 | """Pipeline CLI commands — define and execute multi-step workflows."""
  2 |
  3 | import typer
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#72 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/pipeline.py:24](#)

High-risk permission pattern: ""Execute a pipeline on a notebook."""

```
22 |     input_url: str = typer.Option("", "--input-url", "-u", help="URL variable ($INPUT_URL)",
23 | ) -> None:
24 |     """Execute a pipeline on a notebook."""
25 |     from notebooklm_tools.cli.utils import get_client...
26 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#73 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/pipeline.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Pipeline CLI commands — define and execute multi-step workflows."""
   2 |
   3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#74 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/repl.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Interactive REPL for notebook chat."""
   2 |
   3 | import contextlib
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#75 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Research CLI commands."""
  2 | ...
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#76 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/setup.py:32](#)

High-risk permission pattern: # MCP server command - the binary that clients will execute

```
30 | )
31 |
> 32 | # MCP server command - the binary that clients will execute
  33 | MCP_SERVER_CMD = "notebooklm-mcp"
  34 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#77 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/setup.py:653](#)

High-risk permission pattern: # Execute setup for selected tools

```
651 |         return
652 |
> 653 |         # Execute setup for selected tools
  654 |         console.print()
  655 |         setup_fns = {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#78 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/setup.py:1056](#)

High-risk permission pattern: # Execute removal

```
1054 |         return
1055 |
> 1056 |         # Execute removal
  1057 |         console.print()
  1058 |         removed_count = 0
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#79 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/share.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Sharing CLI commands."""
   2 | ...
   3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#80 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:299](#)

High-risk permission pattern: @app.command("delete")

```
297 |
298 |
> 299 | @app.command("delete")
    300 | def delete_source(
    301 |     source_ids: list[str] = typer.Argument(..., help="Source ID(s) to delete"), # noqa: B008
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#81 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:301](#)

High-risk permission pattern: source_ids: list[str] = typer.Argument(..., help="Source ID(s) to delete"), # n

```
299 | @app.command("delete")
    300 | def delete_source(
> 301 |     source_ids: list[str] = typer.Argument(..., help="Source ID(s) to delete"), # noqa: B008
    302 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
    303 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#82 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:305](#)

High-risk permission pattern: `""Delete source(s) permanently.`

```
303 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
304 | ) -> None:
> 305 |     """Delete source(s) permanently.
306 | ...
307 |     Accepts one or more source IDs for single or bulk deletion.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#83 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:310](#)

High-risk permission pattern: `nlm source delete <source-id> --confirm`

```
308 |
309 |     Examples:
> 310 |         nlm source delete <source-id> --confirm
311 |         nlm source delete <id1> <id2> <id3> --confirm
312 |         ""
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#84 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:311](#)

High-risk permission pattern: `nlm source delete <id1> <id2> <id3> --confirm`

```
309 |     Examples:
310 |         nlm source delete <source-id> --confirm
> 311 |         nlm source delete <id1> <id2> <id3> --confirm
312 |         ""
313 |     resolved_ids = [get_alias_manager().resolve(sid) for sid in source_ids]
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#85 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:318](#)

High-risk permission pattern: `f"Are you sure you want to delete source {resolved_ids[0]}?"`,

```
316 |         if len(resolved_ids) == 1:
317 |             typer.confirm(
> 318 |                 f"Are you sure you want to delete source {resolved_ids[0]}?",
319 |                 abort=True,
320 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#86 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/source.py:323](#)

High-risk permission pattern: `f"Are you sure you want to delete {len(resolved_ids)} sources?"`,

```
321 |         else:
322 |             typer.confirm(
323 |                 f"Are you sure you want to delete {len(resolved_ids)} sources?",
324 |                 abort=True, ...
325 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#87 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/source.py:302](#)

Unrestricted agent autonomy: `confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")`

```
300 | def delete_source(
301 |     source_ids: list[str] = typer.Argument(..., help="Source ID(s) to delete"), # noqa: B008
302 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
303 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
304 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#88 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/source.py:377](#)

Unrestricted agent autonomy: `confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")`

```
375 |         help="Comma-separated source IDs to sync (default: all stale)",
376 |     ),
377 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
378 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
379 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#89 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/source.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Source CLI commands."""
  2 | ...
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#90 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:16](#)

High-risk permission pattern: # Main studio app for status/delete

```
14 | console = make_console()
15 |
> 16 | # Main studio app for status/delete
  17 | app = typer.Typer(
  18 |     help="Manage studio artifacts",
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#91 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:128](#)

High-risk permission pattern: # ===== Studio Status/Delete =====

```
126 |
127 |
> 128 | # ===== Studio Status/Delete =====
  129 |
  130 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#92 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:151](#)

High-risk permission pattern: @app.command("delete")

```
149 |
150 |
> 151 | @app.command("delete")
  152 | def studio_delete(
  153 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#93 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:154](#)

High-risk permission pattern: `artifact_id: str = typer.Argument(..., help="Artifact ID to delete")`,

```
152 | def studio_delete(  
153 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),  
> 154 |     artifact_id: str = typer.Argument(..., help="Artifact ID to delete"),  
155 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),...  
156 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#94 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:158](#)

High-risk permission pattern: `"""Delete a studio artifact permanently."""`

```
156 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),  
157 | ) -> None:  
> 158 |     """Delete a studio artifact permanently."""  
159 |     notebook_id = get_alias_manager().resolve(notebook_id)  
160 |     artifact_id = get_alias_manager().resolve(artifact_id)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#95 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/studio.py:163](#)

High-risk permission pattern: `typer.confirm(f"Are you sure you want to delete artifact {artifact_id}?", abort=`

```
161 |  
162 |     if not confirm:  
> 163 |         typer.confirm(f"Are you sure you want to delete artifact {artifact_id}?", abort=True)  
164 |  
165 |     try:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#96 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:155](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
153 |     notebook_id: str = typer.Argument(..., help="Notebook ID"),
154 |     artifact_id: str = typer.Argument(..., help="Artifact ID to delete"),
> 155 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
156 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),...
157 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#97 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:226](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
224 |         help="Comma-separated source IDs",
225 |     ),
> 226 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
227 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
228 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#98 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:267](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
265 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
266 |     ),
> 267 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
268 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
269 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#99 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:304](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
302 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
303 |     ),
> 304 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
305 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),...
306 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#100 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:360](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
358 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
359 |     ),
> 360 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
361 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
362 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#101 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:388](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
386 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
387 |     ),
> 388 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
389 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
390 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#102 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:425](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
423 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
424 |     ),
> 425 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
426 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),...
427 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#103 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:453](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
451 |         help='Slide revision in format: SLIDE_NUM "instruction" (e.g., --slide 1 "Make title
larger")',
452 |     ),
> 453 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
454 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
455 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#104 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:539](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
537 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
538 |     ),
> 539 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
540 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
541 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#105 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:589](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
587 |     ),
588 |     source_ids: str | None = typer.Option(None, "--source-ids", help="Comma-separated source IDs"),
> 589 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
590 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),...
591 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#106 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/studio.py:623](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
621 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
622 |     ),
> 623 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
624 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
625 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: npm install mcp-secure

#107 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/studio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Studio CLI commands for generation (audio, report, quiz, etc.)."""
  2 |
  3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#108 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/tag.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tag CLI commands – manage notebook tags for smart selection."""
   2 | ...
   3 | import typer
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#109 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:6](#)

High-risk permission pattern: - nlm delete notebook <id> (vs nlm notebook delete <id>)

```
> 4 | - nlm create notebook "Title" (vs nlm notebook create "Title")
   5 | - nlm list notebooks (vs nlm notebook list)
   6 | - nlm delete notebook <id> (vs nlm notebook delete <id>)
   7 |
   8 | Both command structures coexist for user flexibility.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#110 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:491](#)

High-risk permission pattern: # DELETE verb

```
> 489 |
   490 | # =====
   491 | # DELETE verb
   492 | # =====
   493 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#111 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:494](#)

High-risk permission pattern: delete_app = typer.Typer(help="Delete resources (notebooks, sources, artifacts)")

```
> 492 | # =====
   493 |
   494 | delete_app = typer.Typer(help="Delete resources (notebooks, sources, artifacts)")
   495 |
   496 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#112 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:503](#)

High-risk permission pattern: `"""Delete a notebook permanently."""`

```
501 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
502 | ) -> None:
> 503 |     """Delete a notebook permanently."""
504 |     delete_notebook(notebook_id=notebook, confirm=confirm, profile=profile)
505 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#113 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:513](#)

High-risk permission pattern: `"""Delete a source from notebook."""`

```
511 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
512 | ) -> None:
> 513 |     """Delete a source from notebook."""
514 |     delete_source(source_ids=[source], confirm=confirm, profile=profile)
515 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#114 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:524](#)

High-risk permission pattern: `"""Delete a studio artifact permanently."""`

```
522 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
523 | ) -> None:
> 524 |     """Delete a studio artifact permanently."""
525 |     studio_delete(notebook_id=notebook, artifact_id=artifact, confirm=confirm, profile=profile)
526 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#115 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/commands/verbs.py:533](#)

High-risk permission pattern: `""Delete an alias."""`

```
531 |         confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
532 |     ) -> None:
> 533 |         """Delete an alias."""
534 |         delete_alias(name=name, confirm=confirm)...
535 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#116 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:127](#)

Unrestricted agent autonomy: `confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p`

```
125 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
126 |     ),
> 127 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
128 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
129 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#117 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:163](#)

Unrestricted agent autonomy: `confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p`

```
161 |         focus: str | None = typer.Option(None, "--focus", help="Optional focus topic"),
162 |         source_ids: str | None = typer.Option(None, "--source-ids", help="Comma-separated source IDs"),
> 163 |         confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
164 |         profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
165 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#118 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:196](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
194 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
195 |     ),
> 196 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
197 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),...
198 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#119 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:230](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
228 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
229 |     ),
> 230 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
231 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
232 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#120 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:259](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
257 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
258 |     ),
> 259 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
260 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
261 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#121 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:286](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
284 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
285 |     ),
> 286 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
287 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),...
288 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#122 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:311](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
309 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
310 |     ),
> 311 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
312 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
313 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#123 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:333](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
331 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
332 |     ),
> 333 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
334 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
335 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#124 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:354](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
352 |         None, "--source-ids", "-s", help="Comma-separated source IDs"
353 |     ),
> 354 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
355 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),...
356 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#125 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:500](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
498 | def delete_notebook_verb(
499 |     notebook: str = typer.Argument(..., help="Notebook ID or alias"),
> 500 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
501 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
502 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#126 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:510](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
508 | def delete_source_verb(
509 |     source: str = typer.Argument(..., help="Source ID"),
> 510 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
511 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
512 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#127 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:521](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
519 |     notebook: str = typer.Argument(..., help="Notebook ID or alias"),
520 |     artifact: str = typer.Argument(..., help="Artifact ID"),
> 521 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
522 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),...
523 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#128 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:531](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation p

```
529 | def delete_alias_verb(
530 |     name: str = typer.Argument(..., help="Alias name"),
> 531 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation prompt"),
532 | ) -> None:
533 |     """Delete an alias."""
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#129 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/commands/verbs.py:774](#)

Unrestricted agent autonomy: confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation")

```
772 |         None, "--source-ids", "-s", help="Comma-separated source IDs to sync (default: all stale)"
773 |     ),
> 774 |     confirm: bool = typer.Option(False, "--confirm", "-y", help="Skip confirmation"),
775 |     profile: str | None = typer.Option(None, "--profile", "-p", help="Profile to use"),
776 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use tool_choice='none' or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#130 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/commands/verbs.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Verb-first CLI commands for NotebookLM Tools.
  2 | ...
  3 | This module provides alternative command structure:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#131 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/formatters.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Output formatting utilities for NLM CLI."""
  2 |
  3 | from __future__ import annotations
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#132 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:166](#)

High-risk permission pattern: help="Delete the localized Chrome profile data before logging in, to switch Goog

```
164 |         False,
165 |         "--clear",
> 166 |         help="Delete the localized Chrome profile data before logging in, to switch Google accounts",
167 |     ),
168 |     wsl: bool = typer.Option(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#133 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:566](#)

High-risk permission pattern: @profile_app.command("delete")

```
564 |
565 |
> 566 | @profile_app.command("delete")
567 | def profile_delete(
568 |     profile: str = typer.Argument(..., help="Profile name to delete"),
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#134 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:568](#)

High-risk permission pattern: `profile: str = typer.Argument(..., help="Profile name to delete")`,

```
566 | @profile_app.command("delete")
567 | def profile_delete(
> 568 |     profile: str = typer.Argument(..., help="Profile name to delete"),
569 |     confirm: bool = typer.Option(
570 |         False,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#135 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:576](#)

High-risk permission pattern: `"""Delete a profile and its credentials."""`

```
574 |     ),
575 | ) -> None:
> 576 |     """Delete a profile and its credentials."""
577 |     from notebooklm_tools.services.auth import AuthManager
578 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#136 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:588](#)

High-risk permission pattern: `f"Are you sure you want to delete profile '{profile}'?"`,

```
586 |         if not confirm:
587 |             typer.confirm(
> 588 |                 f"Are you sure you want to delete profile '{profile}'?",
589 |                 abort=True,
590 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#137 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:630](#)

High-risk permission pattern: `# Delete old profile`

```
628 |         )
629 |
> 630 |         # Delete old profile
631 |         old_auth.delete_profile()
632 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#138 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/cli/main.py:720](#)

High-risk permission pattern: `app.add_typer(delete_app, name="delete", help="Delete resources (notebooks, sour`

```
718 | app.add_typer(list_app, name="list", help="List resources (notebooks, sources, artifacts)")
719 | app.add_typer(get_app, name="get", help="Get details about resources")
> 720 | app.add_typer(delete_app, name="delete", help="Delete resources (notebooks, sources, artifacts)")
721 | app.add_typer(add_app, name="add", help="Add resources (sources to notebooks)")...
722 | app.add_typer(rename_app, name="rename", help="Rename resources")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#139 AS-008 -- EXCESSIVE AGENCY

HIGH

OWASP: AA-01 | MITRE: T1548 | STRIDE: Elevation of Privilege

Agent configured with unrestricted tool access or auto-approval of dangerous actions

[src/notebooklm_tools/cli/main.py:573](#)

Unrestricted agent autonomy: `help="Skip confirmation prompt",`

```
571 |         "--confirm",
572 |         "-y",
> 573 |         help="Skip confirmation prompt",
574 |     ),
575 | ) -> None:
```

Remediation:

1. Implement mandatory human-in-the-loop for destructive operations (delete, write, execute, send). 2. Use `tool_choice='none'` or explicit tool allowlists instead of 'auto'. 3. Add confirmation prompts before irreversible actions. 4. Log all tool invocations with full parameters for audit.

MCPS Quick Fix: `npm install mcp-secure`

#140 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/cli/utils.py:146](#)

File input near prompt/instruction handling — injection vector

```
144 |
145 |     try:
> 146 |         with open(cache_path, encoding="utf-8") as f:
147 |             data = json.load(f)
148 |
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#141 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/cli/utils.py:164](#)

File input near prompt/instruction handling — injection vector

```
162 |         return
163 |     try:
> 164 |         with open(cache_path, "w", encoding="utf-8") as f:
165 |             json.dump(...)
166 |             {
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#142 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/cli/utils.py:181](#)

File input near prompt/instruction handling — injection vector

```
179 |         url = "https://pypi.org/pypi/notebooklm-mcp-cli/json"
180 |         req = urllib.request.Request(url, headers={"User-Agent": "notebooklm-mcp-cli"})
> 181 |         with urllib.request.urlopen(req, timeout=2) as response: # nsec B310 – URL is hardcoded to
https://pypi.org
182 |             data = json.loads(response.read().decode())
183 |             return data.get("info", {}).get("version")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#143 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/cli/utils.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | import json
2 | import os
3 | import shutil
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#144 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/cli/utils.py:6](#)

Dynamic HTTP with sensitive data context

```
4 | import sys
5 | import time
> 6 | import urllib.request
7 | from pathlib import Path
8 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#145 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/cli/utils.py:180](#)

Dynamic HTTP with sensitive data context

```
178 |         try:
179 |             url = "https://pypi.org/pypi/notebooklm-mcp-cli/json"
> 180 |             req = urllib.request.Request(url, headers={"User-Agent": "notebooklm-mcp-cli"})
181 |             with urllib.request.urlopen(req, timeout=2) as response: # nosec B310 – URL is hardcoded to
https://pypi.org...
182 |                 data = json.loads(response.read()).decode()
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#146 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/cli/utils.py:181](#)

Dynamic HTTP with sensitive data context

```
179 |         url = "https://pypi.org/pypi/notebooklm-mcp-cli/json"
180 |         req = urllib.request.Request(url, headers={"User-Agent": "notebooklm-mcp-cli"})
> 181 |         with urllib.request.urlopen(req, timeout=2) as response: # nosec B310 – URL is hardcoded to
https://pypi.org
182 |             data = json.loads(response.read()).decode()
183 |             return data.get("info", {}).get("version")
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#147 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Core functionality shared between CLI and MCP interfaces."""
2 |
3 | from notebooklm_tools.core import constants
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#148 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/alias.py:77](#)

High-risk permission pattern: `"""Delete an alias. Returns True if deleted."""`

```
75 |  
76 |     def delete_alias(self, name: str) -> bool:  
> 77 |         """Delete an alias. Returns True if deleted."""  
78 |         if name in self._aliases:  
79 |             del self._aliases[name]
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#149 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/alias.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Alias management for NotebookLM CLI."""  
2 |  
3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#150 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/auth.py:487](#)

High-risk permission pattern: `"""Delete the current profile."""`

```
485 |  
486 |     def delete_profile(self) -> None:  
> 487 |         """Delete the current profile."""  
488 |         import shutil  
489 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#151 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:118](#)

File input near prompt/instruction handling — injection vector

```
116 |  
117 |     try:  
> 118 |         with open(cache_path, encoding="utf-8") as f:  
119 |             data = json.load(f)  
120 |             tokens = AuthTokens.from_dict(data)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#152 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:150](#)

File input near prompt/instruction handling — injection vector

```
148 |         cache_path.parent.chmod(stat.S_IRWXU) # 0o700
> 149 |         # TOCTOU-safe: create the file with 0o600 from the start (PR #205)
150 |         fd = os.open(str(cache_path), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
151 |         try:
152 |             f = os.fdopen(fd, "w", encoding="utf-8")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#153 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:152](#)

File input near prompt/instruction handling — injection vector

```
150 |         fd = os.open(str(cache_path), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
> 151 |         try:
152 |             f = os.fdopen(fd, "w", encoding="utf-8")
153 |         except BaseException:
154 |             os.close(fd)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#154 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:449](#)

File input near prompt/instruction handling — injection vector

```
447 |
448 |         # Save cookies with restrictive permissions from creation
> 449 |         fd = os.open(str(self.cookies_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
450 |         try:
451 |             f = os.fdopen(fd, "w", encoding="utf-8")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#155 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:451](#)

File input near prompt/instruction handling — injection vector

```
449 |         fd = os.open(str(self.cookies_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
450 |         try:
> 451 |             f = os.fdopen(fd, "w", encoding="utf-8")
452 |         except BaseException:
453 |             os.close(fd)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#156 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:466](#)

File input near prompt/instruction handling — injection vector

```
464 |         "last_validated": datetime.now().isoformat(),
465 |     }
> 466 |     fd = os.open(str(self.metadata_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
467 |     try:
468 |         f = os.fdopen(fd, "w", encoding="utf-8")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#157 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/auth.py:468](#)

File input near prompt/instruction handling — injection vector

```
466 |         fd = os.open(str(self.metadata_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
467 |         try:
> 468 |             f = os.fdopen(fd, "w", encoding="utf-8")
469 |         except BaseException:
470 |             os.close(fd)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#158 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:147](#)

High-risk permission pattern: `RPC_DELETE_SOURCE = "tGMBJ"` # Delete a source from notebook

```
145 |     RPC_CHECK_FRESHNESS = "yR9Yof" # Check if Drive source is stale
146 |     RPC_SYNC_DRIVE = "FLmJqe" # Sync Drive source with latest content
> 147 |     RPC_DELETE_SOURCE = "tGMBJ" # Delete a source from notebook
148 |     RPC_RENAME_SOURCE = "b7Wfje" # Rename a source
149 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#159 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:167](#)

High-risk permission pattern: `RPC_DELETE_STUDIO = "V5N4be"` # Delete Audio or Video Overview

```
165 |     RPC_CREATE_STUDIO = "R7cb6c" # Create Audio or Video Overview
> 166 |     RPC_POLL_STUDIO = "gArtLc" # Poll for studio content status
167 |     RPC_DELETE_STUDIO = "V5N4be" # Delete Audio or Video Overview
168 |     RPC_RENAME_ARTIFACT = "rc3d8d" # Rename any studio artifact (Audio, Video, etc.)...
169 |     RPC_GET_INTERACTIVE_HTML = "v9rmvd" # Fetch quiz/flashcard HTML content
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#160 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:176](#)

High-risk permission pattern: `RPC_DELETE_MIND_MAP = "AH0mwd"` # Delete a mind map

```
174 |     RPC_SAVE_MIND_MAP = "CYK0Xb" # Save generated mind map to notebook
> 175 |     RPC_LIST_MIND_MAPS = "cFji9" # List existing mind maps
176 |     RPC_DELETE_MIND_MAP = "AH0mwd" # Delete a mind map
177 |
178 | # Notes RPCs (share RPC IDs with mind maps, differ by parameters)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#161 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:182](#)

High-risk permission pattern: `RPC_DELETE_NOTE = "AH0mwd"` # Delete note permanently (same as `DELETE_MIND_MAP`)

```
180 |     RPC_GET_NOTES = "cFji9" # List notes and mind maps (same as LIST_MIND_MAPS)
181 |     RPC_UPDATE_NOTE = "cYAfTb" # Update note content/title
> 182 |     RPC_DELETE_NOTE = "AH0mwd" # Delete note permanently (same as DELETE_MIND_MAP)
183 |
184 | # Label RPCs (source organization)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#162 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:187](#)

High-risk permission pattern: `RPC_LABEL_DELETE = "GyzE7e"` # Delete one or more labels

```
185 |     RPC_LABEL_MANAGE = "agX4Bc" # Auto-label sources / create label / list labels
186 |     RPC_LABEL_MUTATE = "le8sX" # Rename label / set emoji / move source to label
> 187 |     RPC_LABEL_DELETE = "GyzE7e" # Delete one or more labels
188 | ...
189 |     # Sharing RPCs
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#163 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/base.py:668](#)

High-risk permission pattern: `"""Execute an RPC call and return the extracted result.`

```
666 |         _server_retry: int = 0,
667 |     ) -> Any:
> 668 |         """Execute an RPC call and return the extracted result.
669 |
670 |         Includes automatic retry on auth failures with three-layer recovery:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#164 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/base.py:17](#)

Dynamic HTTP with sensitive data context

```
15 | import secrets
16 | import threading
> 17 | import urllib.parse
18 | from collections import OrderedDict
19 | from typing import Any
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#165 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/base.py:509](#)

Dynamic HTTP with sensitive data context

```
507 |
508 |     # URL encode (safe='' encodes all characters including /)
> 509 |     body_parts = [f"f.req={urllib.parse.quote(f_req_json, safe='')}"]
510 |
511 |     if self.csrf_token:
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#166 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/base.py:512](#)

Dynamic HTTP with sensitive data context

```
510 |  
511 |         if self.csrf_token:  
> 512 |             body_parts.append(f"at={urllib.parse.quote(self.csrf_token, safe='')}")  
513 | ...  
514 |         # Add trailing & to match NotebookLM's format
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#167 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/base.py:530](#)

Dynamic HTTP with sensitive data context

```
528 |         params["f.sid"] = self._session_id  
529 |  
> 530 |         query = urllib.parse.urlencode(params)  
531 |         return f"{self._get_batchexecute_url()}?{query}"  
532 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#168 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/client.py:58](#)

High-risk permission pattern: - Notebook management (list, create, rename, delete)

```
56 |  
57 |         This class extends BaseClient with all domain-specific operations:  
> 58 |         - Notebook management (list, create, rename, delete)  
59 |         - Source management (add, sync, delete)  
60 |         - Query/chat operations
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#169 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/client.py:59](#)

High-risk permission pattern: - Source management (add, sync, delete)

```
57 | This class extends BaseClient with all domain-specific operations:
58 | - Notebook management (list, create, rename, delete)
> 59 | - Source management (add, sync, delete)
60 | - Query/chat operations...
61 | - Studio content (audio, video, reports, flashcards, etc.)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#170 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/client.py:64](#)

High-risk permission pattern: - Notes management (create, list, update, delete)

```
62 | - Research operations
63 | - Sharing and collaboration
> 64 | - Notes management (create, list, update, delete)
65 |
66 | All HTTP/RPC infrastructure is provided by the BaseClient base class.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#171 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/notebooklm_tools/core/client.py:19](#)

Dependency without integrity verification

```
17 |
18 | # Import utility functions from utils module
> 19 | # Import dataclasses from data_types module (re-exported for backward compatibility)
20 | # Import exception classes from errors module (re-exported for backward compatibility)
21 | from .errors import (
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#172 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/client.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
2 | """NotebookLM MCP API client (notebooklm.google.com).
3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#173 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/constants.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """
  2 | Constants and mappings for NotebookLM API...
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#174 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/conversation.py:241](#)

High-risk permission pattern: ""Delete the chat history for a notebook.

```
239 |
240 |     def delete_chat_history(self, notebook_id: str, conversation_id: str) -> bool:
> 241 |         """Delete the chat history for a notebook.
242 |
243 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#175 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/conversation.py:245](#)

High-risk permission pattern: conversation_id: The conversation UUID to delete

```
243 |         Args:
244 |             notebook_id: The notebook UUID
> 245 |             conversation_id: The conversation UUID to delete
246 |
247 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#176 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/conversation.py:11](#)

Dynamic HTTP with sensitive data context

```
9 | import logging
10 | import os
> 11 | import urllib.parse
12 | from typing import Any, Protocol, cast
13 |
```


Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#177 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/conversation.py:346](#)

Dynamic HTTP with sensitive data context

```
344 |  
345 |         # URL encode with safe='' to encode all characters including /  
> 346 |         body_parts = [f"f.req={urllib.parse.quote(f_req_json, safe='')}"]  
347 |         if self.csrf_token:...  
348 |             body_parts.append(f"at={urllib.parse.quote(self.csrf_token, safe='')}")
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#178 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/conversation.py:348](#)

Dynamic HTTP with sensitive data context

```
346 |         body_parts = [f"f.req={urllib.parse.quote(f_req_json, safe='')}"]  
347 |         if self.csrf_token:  
> 348 |             body_parts.append(f"at={urllib.parse.quote(self.csrf_token, safe='')}")  
349 |         # Add trailing & to match NotebookLM's format  
350 |         body = "&".join(body_parts) + "&"
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#179 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/conversation.py:364](#)

Dynamic HTTP with sensitive data context

```
362 |         url_params["f.sid"] = self._session_id  
363 |  
> 364 |         query_string = urllib.parse.urlencode(url_params)  
365 |         url = f"{self._get_base_url()}{self.QUERY_ENDPOINT}?{query_string}"  
366 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#180 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/data_types.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | # src/notebooklm_tools/core/data_types.py
  2 | """Dataclasses for NotebookLM API client....
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#181 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/download.py:147](#)

High-risk permission pattern: cookies.delete("OSID", domain=domain)

```
145 |         # an invalid session and redirects to ServiceLogin, breaking downloads.
146 |         for domain in ("google.com", "googleusercontent.com"):
> 147 |             cookies.delete("OSID", domain=domain)
148 |             cookies.delete("__Secure-OSID", domain=domain)
149 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#182 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/download.py:148](#)

High-risk permission pattern: cookies.delete("__Secure-OSID", domain=domain)

```
146 |         for domain in ("google.com", "googleusercontent.com"):
147 |             cookies.delete("OSID", domain=domain)
> 148 |             cookies.delete("__Secure-OSID", domain=domain)
149 |
150 |         # Per-chunk timeouts: 10s connect, 30s per chunk read/write
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#183 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/download.py:125](#)

File input near prompt/instruction handling — injection vector

```
123 |         {"User-Agent": "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36"},
124 |         )
> 125 |         # Mirror Chrome's window.open() from notebooklm.google.com to a cross-domain
126 |         # artifact host (lh3.googleusercontent.com / lh3.google.com). The audio CDN
127 |         # treats "Sec-Fetch-Site: none" as an address-bar navigation and returns 403;
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#184 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/download.py:128](#)

File input near prompt/instruction handling — injection vector

```
126 |         # artifact host (lh3.googleusercontent.com / lh3.google.com). The audio CDN
127 |         # treats "Sec-Fetch-Site: none" as an address-bar navigation and returns 403;
> 128 |         # the UI's Download button succeeds because window.open() makes Chrome stamp
129 |         # the request with "Sec-Fetch-Site: cross-site" + Referer=notebooklm.google.com....
130 |         headers = {
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#185 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/download.py:186](#)

File input near prompt/instruction handling — injection vector

```
184 |
185 |         # Not an auth error - write first chunk and continue
> 186 |         with open(temp_file, "wb") as f:
187 |             f.write(first_chunk)
188 |             bytes_downloaded = len(first_chunk)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#186 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/download.py:203](#)

File input near prompt/instruction handling — injection vector

```
201 |         # Binary content - stream directly
202 |         bytes_downloaded = 0
> 203 |         with open(temp_file, "wb") as f:
204 |             async for chunk in response.aiter_bytes(chunk_size=chunk_size):
205 |                 f.write(chunk)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#187 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/core/download.py:901](#)

File input near prompt/instruction handling — injection vector

```
899 |         output.parent.mkdir(parents=True, exist_ok=True)
900 |
> 901 |         with open(output, "w", newline="", encoding="utf-8-sig") as f:
902 |             writer = csv.writer(f)
903 |             writer.writerow(headers)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#188 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/notebooklm_tools/core/download.py:980](#)

Known injection pattern detected

```
978 |         Tries multiple extraction patterns for robustness:
979 |         1. data-app-data attribute (primary)
> 980 |         2. <script id="application-data"> tag (fallback)
981 |         3. Other common patterns
982 |
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#189 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[src/notebooklm_tools/core/download.py:1008](#)

Known injection pattern detected

```
1006 |         logger.debug(f"JSON preview: {decoded_json[:200]}...")
1007 |
> 1008 |         # Pattern 2: <script id="application-data"> tag
1009 |         match = re.search(
1010 |             r'<script[^>]+id=["\']application-data["\'][^>]*>(.*?)</script>',
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#190 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/errors.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | # src/notebooklm_tools/core/errors.py
2 | """Exception classes for NotebookLM API artifacts and client errors.
3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#191 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/exceptions.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Custom exceptions for NLM CLI."""
    2 | ...
    3 | from typing import Any
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#192 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/exports.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
    2 | """ExportMixin - Export artifacts to Google Docs/Sheets.
    3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#193 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/labels.py:88](#)

High-risk permission pattern: """Delete one or more labels. Sources are NOT deleted."""

```
86 |
87 |     def delete_labels(self, notebook_id: str, label_ids: list[str]) -> bool:
> 88 |         """Delete one or more labels. Sources are NOT deleted."""
    89 |         params = [[2], notebook_id, label_ids]
    90 |         result = self._call_rpc(self.RPC_LABEL_DELETE, params, f"/notebook/{notebook_id}")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#194 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/labels.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """LabelsMixin - Source label management operations.
    2 |
    3 | Requires 5+ sources for auto-label to be available in the NotebookLM UI.
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#195 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/models.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Pydantic models for NotebookLM data structures."""
    2 | ...
    3 | from datetime import datetime
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#196 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/notebooks.py:10](#)

High-risk permission pattern: - delete_notebook: Delete a notebook

```
> 8 | - rename_notebook: Rename a notebook
    9 | - configure_chat: Configure chat settings
   10 | - delete_notebook: Delete a notebook
   11 | """
   12 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#197 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/notebooks.py:242](#)

High-risk permission pattern: ""Delete a notebook permanently.

```
> 240 |
    241 |     def delete_notebook(self, notebook_id: str) -> bool:
    242 |         """Delete a notebook permanently.
    243 |
    244 |         WARNING: This action is IRREVERSIBLE. The notebook and all its sources,
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#198 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/notebooks.py:248](#)

High-risk permission pattern: notebook_id: The notebook UUID to delete

```
> 246 |
    247 |     Args:
    248 |         notebook_id: The notebook UUID to delete
    249 |
    250 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#199 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/notes.py:217](#)

High-risk permission pattern: """Delete a note permanently.

```
215 |  
> 216 |         def delete_note(self, note_id: str, notebook_id: str) -> bool:  
    217 |             """Delete a note permanently.  
    218 | ...  
    219 |             Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#200 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/notes.py:230](#)

High-risk permission pattern: # Returns null on success (soft-delete: clears content, keeps ID)

```
228 |         self._call_rpc(self.RPC_DELETE_NOTE, params, f"/notebook/{notebook_id}")  
229 |  
> 230 |         # Returns null on success (soft-delete: clears content, keeps ID)  
    231 |         return True # If no exception was raised, consider it success  
    232 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#201 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/notes.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """NotesMixin - Note management operations.  
  2 |  
  3 | This mixin provides note-related operations:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#202 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
   2 | """Research mixin for NotebookLM client...
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#203 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/retry.py:88](#)

High-risk permission pattern: """Execute a callable with retry logic for transient server errors.

```
> 86 |     **kwargs: Any,
   87 | ) -> Any:
   88 |     """Execute a callable with retry logic for transient server errors.
   89 |
   90 |     Use this for one-off retry wrapping where a decorator isn't practical
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#204 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/retry.py:94](#)

High-risk permission pattern: func: The callable to execute.

```
> 92 |
   93 |     Args:
   94 |         func: The callable to execute.
   95 |         *args: Positional arguments for the callable.
   96 |         max_retries: Maximum retry attempts.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#205 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/sharing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """SharingMixin - Notebook sharing and collaboration operations.
   2 |
   3 | This mixin provides sharing-related operations:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#206 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:6](#)

High-risk permission pattern: - delete_source: Delete a source permanently

```
4 | - check_source_freshness: Check if Drive source is up-to-date
5 | - sync_drive_source: Sync a Drive source with latest content
> 6 | - delete_source: Delete a source permanently
7 | - get_notebook_sources_with_types: Get sources with type info...
8 | - add_url_source: Add URL/YouTube as source
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#207 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:241](#)

High-risk permission pattern: ""Delete a source from a notebook permanently.

```
239 |
240 |     def delete_source(self, source_id: str) -> bool:
> 241 |         """Delete a source from a notebook permanently.
242 |
243 |         WARNING: This action is IRREVERSIBLE. The source will be permanently
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#208 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:247](#)

High-risk permission pattern: source_id: The source UUID to delete

```
245 |
246 |     Args:
> 247 |         source_id: The source UUID to delete
248 |
249 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#209 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:252](#)

High-risk permission pattern: # Delete source params: [[["source_id"]], [2]]

```
250 |         True on success, False on failure
251 |         """
> 252 |         # Delete source params: [[["source_id"]], [2]]
253 |         # Note: Extra nesting compared to delete_notebook
254 |         params = [[["source_id"]], [2]]
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#210 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:262](#)

High-risk permission pattern: """Delete multiple sources from a notebook in a single request.

```
260 |  
> 261 |     def delete_sources(self, source_ids: list[str]) -> bool:  
    262 |         """Delete multiple sources from a notebook in a single request.  
    263 | ...  
    264 |         WARNING: This action is IRREVERSIBLE. All specified sources will be
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#211 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:268](#)

High-risk permission pattern: source_ids: List of source UUIDs to delete

```
266 |  
> 267 |         Args:  
    268 |             source_ids: List of source UUIDs to delete  
    269 |  
    270 |         Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#212 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/sources.py:273](#)

High-risk permission pattern: # Batch delete params: [[["id1"], ["id2"], ...], [2]]

```
271 |         True on success, False on failure  
272 |         """  
> 273 |         # Batch delete params: [[["id1"], ["id2"], ...], [2]]  
    274 |         params = [[sid for sid in source_ids], [2]]  
    275 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#213 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/core/sources.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """SourceMixin - Source management operations.
    2 | ...
    3 | This mixin provides source-related operations:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#214 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/studio.py:513](#)

High-risk permission pattern: ""Delete a studio artifact (Audio, Video, or Mind Map).

```
511 |
512 |     def delete_studio_artifact(self, artifact_id: str, notebook_id: str | None = None) -> bool:
> 513 |         """Delete a studio artifact (Audio, Video, or Mind Map).
514 |
515 |         WARNING: This action is IRREVERSIBLE. The artifact will be permanently deleted.
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#215 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/studio.py:518](#)

High-risk permission pattern: artifact_id: The artifact UUID to delete

```
516 |
517 |     Args:
> 518 |         artifact_id: The artifact UUID to delete
519 |         notebook_id: Optional notebook ID. Required for deleting Mind Maps.
520 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#216 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/studio.py:535](#)

High-risk permission pattern: "Standard studio delete failed, trying fallback: %s", _e

```
533 |
534 |         _logging.getLogger(__name__).debug(
> 535 |             "Standard studio delete failed, trying fallback: %s", _e
536 |         )
537 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#217 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/core/studio.py:546](#)

High-risk permission pattern: ""Delete a Mind Map artifact using the observed two-step RPC sequence.

```
544 |  
> 545 |     def delete_mind_map(self, notebook_id: str, mind_map_id: str) -> bool:  
546 |         """Delete a Mind Map artifact using the observed two-step RPC sequence.  
547 | ...  
548 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#218 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/utils.py:4](#)

Dynamic HTTP with sensitive data context

```
2 |  
> 3 | import json  
4 | import urllib.parse  
5 | from datetime import UTC, datetime  
6 | from typing import Any
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#219 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/utils.py:67](#)

Dynamic HTTP with sensitive data context

```
65 |     result = {}  
66 |     try:  
> 67 |         parsed = urllib.parse.parse_qs(body.rstrip("&"))  
68 |         if "f.req" in parsed:  
69 |             f_req_raw = parsed["f.req"][0]
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#220 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/utils.py:97](#)

Dynamic HTTP with sensitive data context

```
95 |     """Parse URL query parameters for debug display."""
96 |     try:
> 97 |         parsed = urllib.parse.urlparse(url)
98 |         params = urllib.parse.parse_qs(parsed.query)...
99 |         return {k: v[0] if len(v) == 1 else v for k, v in params.items()}
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#221 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/core/utils.py:98](#)

Dynamic HTTP with sensitive data context

```
96 |     try:
97 |         parsed = urllib.parse.urlparse(url)
> 98 |         params = urllib.parse.parse_qs(parsed.query)
99 |         return {k: v[0] if len(v) == 1 else v for k, v in params.items()}
100 |     except Exception:
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#222 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """MCP server interface for NotebookLM."""
2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#223 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/server.py:17](#)

High-risk permission pattern: - notes.py: Note management (create, list, update, delete)

```
15 | - chat.py: Query and conversation management
16 | - exports.py: Export artifacts to Google Docs/Sheets
> 17 | - notes.py: Note management (create, list, update, delete)
18 | """
19 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#224 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/__init__.py:98](#)

High-risk permission pattern: # Batch (1 consolidated — action: query|add_source|create|delete|studio)

```
96 | # Server (1)
97 | "server_info",
> 98 | # Batch (1 consolidated — action: query|add_source|create|delete|studio)
99 | "batch", ...
100 | # Cross-notebook (1)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#225 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """MCP Tools - Modular tool definitions for NotebookLM MCP Server."""
2 |
3 | # Import all tools from submodules for registration
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#226 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/auth.py:5](#)

Dynamic HTTP with sensitive data context

```
3 | import os
4 | import time
> 5 | import urllib.parse
6 |
7 | from ._utils import (
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#227 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/auth.py:144](#)

Dynamic HTTP with sensitive data context

```
142 |         if not csrf_token and request_body and "at=" in request_body:
143 |             at_part = request_body.split("at=")[1].split("&")[0]
> 144 |             csrf_token = urllib.parse.unquote(at_part)
145 | ...
146 |         # Try to extract session ID from request URL if provided
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#228 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/auth.py:149](#)

Dynamic HTTP with sensitive data context

```
147 |         if not session_id and request_url and "f.sid=" in request_url:
148 |             sid_part = request_url.split("f.sid=")[1].split("&")[0]
> 149 |             session_id = urllib.parse.unquote(sid_part)
150 |
151 |         # Try to extract build label from request URL if provided
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#229 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/auth.py:155](#)

Dynamic HTTP with sensitive data context

```
153 |         if request_url and "bl=" in request_url:
154 |             bl_part = request_url.split("bl=")[1].split("&")[0]
> 155 |             build_label = urllib.parse.unquote(bl_part)
156 |
157 |         # Create and save tokens
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#230 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:26](#)

High-risk permission pattern: - delete: Delete multiple notebooks (IRREVERSIBLE, requires confirm=True)

```
24 |         - add_source: Add the same source URL to multiple notebooks
25 |         - create: Create multiple notebooks at once
> 26 |         - delete: Delete multiple notebooks (IRREVERSIBLE, requires confirm=True)
27 |         - studio: Generate studio artifacts across multiple notebooks
28 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#231 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:30](#)

High-risk permission pattern: action: Operation to perform (query, add_source, create, delete, studio)

```
28 |  
> 29 |     Args:  
30 |         action: Operation to perform (query, add_source, create, delete, studio)  
31 |         query: Question to ask (for action=query)...  
32 |         source_url: URL to add (for action=add_source)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#232 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:38](#)

High-risk permission pattern: confirm: Must be True for delete action

```
36 |         tags: Comma-separated tags to select notebooks  
> 37 |         all: Apply to ALL notebooks  
38 |         confirm: Must be True for delete action  
39 |         """  
40 |     try:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#233 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:74](#)

High-risk permission pattern: elif action == "delete":

```
72 |         return {"status": "success", **result}  
> 73 |  
74 |         elif action == "delete":  
75 |             if not confirm:  
76 |                 return {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#234 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:78](#)

High-risk permission pattern: "error": "Batch delete not confirmed. Ask the user to confirm before setting con

```
76 |             return {
77 |                 "status": "error",
> 78 |                 "error": "Batch delete not confirmed. Ask the user to confirm before setting
confirm=True.",
79 |                 "warning": "This action is IRREVERSIBLE. Multiple notebooks will be permanently
deleted.",
80 |             }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#235 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/batch.py:93](#)

High-risk permission pattern: "error": f"Unknown action: {action}. Use: query, add_source, create, delete, stu

```
91 |             return {
92 |                 "status": "error",
> 93 |                 "error": f"Unknown action: {action}. Use: query, add_source, create, delete, studio",
94 |             }
95 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#236 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/batch.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Batch operations – consolidated tool for multi-notebook actions."""
2 |
3 | from ...services import batch as batch_service
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#237 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/chat.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Chat tools - Query and conversation management."""
2 |
3 | from ...services import ServiceError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#238 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/cross_notebook.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Cross-notebook tools - query across multiple notebooks."""
  2 | ...
  3 | from ...services import cross_notebook as cross_notebook_service
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#239 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/downloads.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Download tools - Consolidated download_artifact for all artifact types."""
  2 |
  3 | import asyncio
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#240 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/exports.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Export tools - Export artifacts to Google Docs/Sheets."""
  2 |
  3 | from ...services import ServiceError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#241 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:25](#)

High-risk permission pattern: Supports: auto, list, reorganize, create, rename, set_emoji, move_source, delete

```
23 |         for auto-labeling. Sources can belong to multiple labels simultaneously.
24 |
> 25 |         Supports: auto, list, reorganize, create, rename, set_emoji, move_source, delete
26 |     ...
27 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#242 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:37](#)

High-risk permission pattern: - delete: Delete label(s) permanently (requires label_id or label_ids, confirm=T

```
35 |         - set_emoji: Set or clear emoji on a label (requires label_id, emoji)
36 |         - move_source: Assign a source to a label (requires label_id, source_id)
> 37 |         - delete: Delete label(s) permanently (requires label_id or label_ids, confirm=True)
38 |         label_id: Label UUID (required for rename, set_emoji, move_source, delete)
39 |         label_ids: List of label UUIDs for batch delete (alternative to label_id)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#243 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:38](#)

High-risk permission pattern: label_id: Label UUID (required for rename, set_emoji, move_source, delete)

```
36 |         - move_source: Assign a source to a label (requires label_id, source_id)
37 |         - delete: Delete label(s) permanently (requires label_id or label_ids, confirm=True)
> 38 |         label_id: Label UUID (required for rename, set_emoji, move_source, delete)
39 |         label_ids: List of label UUIDs for batch delete (alternative to label_id)
40 |         name: Label display name (required for create and rename)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#244 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:39](#)

High-risk permission pattern: label_ids: List of label UUIDs for batch delete (alternative to label_id)

```
37 |         - delete: Delete label(s) permanently (requires label_id or label_ids, confirm=True)
38 |         label_id: Label UUID (required for rename, set_emoji, move_source, delete)
> 39 |         label_ids: List of label UUIDs for batch delete (alternative to label_id)
40 |         name: Label display name (required for create and rename)
41 |         emoji: Emoji character for set_emoji (e.g. "ðŸŒˆ"), or "" to clear
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#245 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:45](#)

High-risk permission pattern: confirm: Must be True for delete action and for reorganize with unlabeled_only=F

```
43 |         unlabeled_only: For reorganize: if True, only label sources not yet in any label.  
> 44 |         If False (default), replaces ALL existing labels from scratch (requires confirm=True).  
45 |         confirm: Must be True for delete action and for reorganize with unlabeled_only=False  
46 | ...  
47 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#246 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:59](#)

High-risk permission pattern: label(notebook_id="abc", action="delete", label_id="xyz", confirm=True)

```
57 |         label(notebook_id="abc", action="set_emoji", label_id="xyz", emoji="ðŸŒˆ")  
58 |         label(notebook_id="abc", action="move_source", label_id="xyz", source_id="src-id")  
> 59 |         label(notebook_id="abc", action="delete", label_id="xyz", confirm=True)  
60 |     """  
61 |     valid_actions = (
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#247 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:69](#)

High-risk permission pattern: "delete",

```
67 |         "set_emoji",  
68 |         "move_source",  
> 69 |         "delete",  
70 |     )  
71 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#248 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:130](#)

High-risk permission pattern: `elif action == "delete":`

```
128 |         return {"status": "success", "action": "move_source", **result}
129 |
> 130 |         elif action == "delete":
131 |             ids = coerce_list(label_ids) or ([label_id] if label_id else None)...
132 |             if not ids:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#249 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:133](#)

High-risk permission pattern: `return error_result("label_id or label_ids is required for action='delete'")`

```
131 |             ids = coerce_list(label_ids) or ([label_id] if label_id else None)
132 |             if not ids:
> 133 |                 return error_result("label_id or label_ids is required for action='delete'")
134 |             if not confirm:
135 |                 return error_result(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#250 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/labels.py:140](#)

High-risk permission pattern: `return {"status": "success", "action": "delete", **result}`

```
138 |         )
139 |         result = labels_service.delete_labels(client, notebook_id, ids)
> 140 |         return {"status": "success", "action": "delete", **result}
141 |
142 |         return error_result(f"Unhandled action: {action}")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#251 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/labels.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Label tools - Source label management with consolidated label tool."""
2 |
3 | from ...services import ServiceError, ValidationError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#252 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notebooks.py:116](#)

High-risk permission pattern: ""Delete notebook permanently. IRREVERSIBLE. Requires confirm=True.

```
114 | @logged_tool()
115 | def notebook_delete(notebook_id: str, confirm: bool = False) -> ResultDict:
> 116 |     """Delete notebook permanently. IRREVERSIBLE. Requires confirm=True.
117 | ...
118 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#253 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/notebooks.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Notebook tools - Notebook management operations."""
2 |
3 | from ...services import ServiceError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#254 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:19](#)

High-risk permission pattern: Supports: create, list, update, delete

```
17 |     """Manage notes in a notebook. Unified tool for all note operations.
18 |
> 19 |     Supports: create, list, update, delete
20 |
21 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#255 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:27](#)

High-risk permission pattern: - delete: Delete a note permanently (requires confirm=True)

```
25 |         - list: List all notes in notebook
26 |         - update: Update an existing note
> 27 |         - delete: Delete a note permanently (requires confirm=True)
28 |         note_id: Note UUID (required for update/delete)
29 |         content: Note content (required for create, optional for update)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#256 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:28](#)

High-risk permission pattern: note_id: Note UUID (required for update/delete)

```
26 |         - update: Update an existing note
27 |         - delete: Delete a note permanently (requires confirm=True)
> 28 |         note_id: Note UUID (required for update/delete)
29 |         content: Note content (required for create, optional for update)...
30 |         title: Note title (optional for create/update)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#257 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:31](#)

High-risk permission pattern: confirm: Must be True for delete action

```
29 |         content: Note content (required for create, optional for update)
30 |         title: Note title (optional for create/update)
> 31 |         confirm: Must be True for delete action
32 |
33 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#258 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:40](#)

High-risk permission pattern: note(notebook_id="abc", action="delete", note_id="xyz", confirm=True)

```
38 |         note(notebook_id="abc", action="create", content="My note", title="Title")
39 |         note(notebook_id="abc", action="update", note_id="xyz", content="Updated")
> 40 |         note(notebook_id="abc", action="delete", note_id="xyz", confirm=True)
41 |         """
42 |         valid_actions = ("create", "list", "update", "delete")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#259 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:42](#)

High-risk permission pattern: `valid_actions = ("create", "list", "update", "delete")`

```
40 |         note(notebook_id="abc", action="delete", note_id="xyz", confirm=True)
41 |         """
42 |         valid_actions = ("create", "list", "update", "delete")
43 |     ...
44 |         if action not in valid_actions:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#260 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:67](#)

High-risk permission pattern: `elif action == "delete":`

```
65 |         return {"status": "success", "action": "update", **update_result}
66 |
67 |         elif action == "delete":
68 |             if not note_id:
69 |                 return error_result("note_id is required for action='delete'")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#261 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:69](#)

High-risk permission pattern: `return error_result("note_id is required for action='delete'")`

```
67 |         elif action == "delete":
68 |             if not note_id:
69 |                 return error_result("note_id is required for action='delete'")
70 |             if not confirm:
71 |                 return error_result(
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#262 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/notes.py:76](#)

High-risk permission pattern: `return {"status": "success", "action": "delete", **delete_result}`

```
74 |         )
75 |         delete_result = notes_service.delete_note(client, notebook_id, note_id)
76 |         return {"status": "success", "action": "delete", **delete_result}
77 |
78 |         return error_result(f"Unhandled action: {action}")
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#263 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/notes.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Notes tools - Note management with consolidated note tool."""
  2 | ...
  3 | from ...services import ServiceError, ValidationError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#264 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/pipeline.py:15](#)

High-risk permission pattern: """Manage and execute multi-step notebook pipelines.

```
13 |     input_url: str = "",
14 | ) -> ResultDict:
> 15 |     """Manage and execute multi-step notebook pipelines.
16 |
17 |     Actions:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#265 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/pipeline.py:18](#)

High-risk permission pattern: - run: Execute a pipeline on a notebook

```
16 |
17 |     Actions:
> 18 |         - run: Execute a pipeline on a notebook
19 |         - list: List all available pipelines (builtin and user-defined)
20 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#266 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/pipeline.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Pipeline tools – consolidated tool for multi-step notebook workflows."""
  2 | ...
  3 | from ...services import pipeline as pipeline_service
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#267 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Research tools - Deep research and source discovery."""
  2 | ...
  3 | from ...services import ServiceError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#268 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/notebooklm_tools/mcp/tools/server.py:102](#)

Dependency without integrity verification

```
100 |         "auth_status": _check_auth_status(),
101 |         "update_command": "uv tool upgrade notebooklm-mcp-cli",
> 102 |         "pip_update_command": "pip install --upgrade notebooklm-mcp-cli",
103 |     }
104 |
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#269 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/server.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Server tools - Server info and version checking."""
  2 | ...
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#270 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/server.py:4](#)

Dynamic HTTP with sensitive data context

```
2 |  
> 3 | import json  
4 | import urllib.request  
5 | from typing import Any, cast...  
6 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#271 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/server.py:20](#)

Dynamic HTTP with sensitive data context

```
18 |         try:  
> 19 |             url = "https://pypi.org/pypi/notebooklm-mcp-cli/json"  
20 |             req = urllib.request.Request(url, headers={"User-Agent": "notebooklm-mcp-cli"})  
21 |             with urllib.request.urlopen(req, timeout=2) as response: # nosec B310 – URL is hardcoded to  
https://pypi.org  
22 |                 data = cast(dict[str, Any], json.loads(response.read().decode()))
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#272 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/mcp/tools/server.py:21](#)

Dynamic HTTP with sensitive data context

```
19 |         url = "https://pypi.org/pypi/notebooklm-mcp-cli/json"  
> 20 |         req = urllib.request.Request(url, headers={"User-Agent": "notebooklm-mcp-cli"})  
21 |         with urllib.request.urlopen(req, timeout=2) as response: # nosec B310 – URL is hardcoded to  
https://pypi.org  
22 |             data = cast(dict[str, Any], json.loads(response.read().decode()))  
23 |             info = data.get("info")
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#273 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/sharing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Sharing tools - Notebook sharing and collaboration."""
  2 | ...
  3 | from ...services import ServiceError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#274 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/smart_select.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Smart select tools - consolidated tag management and notebook selection."""
  2 | ...
  3 | from ...services import smart_select as smart_select_service
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#275 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/sources.py:183](#)

High-risk permission pattern: """Delete source(s) permanently. IRREVERSIBLE. Requires confirm=True.

```
181 |     confirm: bool = False,
182 | ) -> ResultDict:
> 183 |     """Delete source(s) permanently. IRREVERSIBLE. Requires confirm=True.
184 |
185 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#276 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/sources.py:186](#)

High-risk permission pattern: source_id: Source UUID to delete (single)

```
184 |
185 |     Args:
> 186 |     source_id: Source UUID to delete (single)
187 |     source_ids: List of source UUIDs to delete (bulk, alternative to source_id)
188 |     confirm: Must be True after user approval
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#277 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/sources.py:187](#)

High-risk permission pattern: source_ids: List of source UUIDs to delete (bulk, alternative to source_id)

```
185 |     Args:
186 |         source_id: Source UUID to delete (single)
> 187 |         source_ids: List of source UUIDs to delete (bulk, alternative to source_id)
188 |         confirm: Must be True after user approval...
189 |         """
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#278 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/sources.py:202](#)

High-risk permission pattern: # Bulk delete: when source_ids list is provided

```
200 |         coerced_source_ids: list[str] | None = coerce_list(source_ids)
201 |
> 202 |         # Bulk delete: when source_ids list is provided
203 |         if coerced_source_ids:
204 |             sources_service.delete_sources(client, coerced_source_ids)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#279 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/sources.py:211](#)

High-risk permission pattern: # Single delete (existing behavior)

```
209 |         }
210 |
> 211 |         # Single delete (existing behavior)
212 |         if not source_id:
213 |             return error_result("Either source_id or source_ids is required.")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#280 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/sources.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Source tools - Source management with consolidated source_add."""
2 |
3 | from ...services import ServiceError, ValidationError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#281 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/mcp/tools/studio.py:331](#)

High-risk permission pattern: ""Delete studio artifact. IRREVERSIBLE. Requires confirm=True.

```
329 |         confirm: bool = False,  
330 |     ) -> ResultDict:  
> 331 |         ""Delete studio artifact. IRREVERSIBLE. Requires confirm=True.  
332 |     ...  
333 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#282 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/studio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | ""Studio tools - Artifact creation with consolidated studio_create.""  
2 |  
3 | import time as _time
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#283 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/mcp/tools/studio_advanced.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | ""Studio advanced – helper for studio type reference data.""  
2 |  
3 | from typing import Any
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#284 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | ""Service layer for NotebookLM MCP CLI.  
2 |  
3 | This package contains the shared business logic, validation, and error handling
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#285 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/_compat.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Python version compatibility shims for the services layer."""
  2 | ...
  3 | import sys
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#286 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[src/notebooklm_tools/services/auth.py:21](#)

Dangerous execution: services.auth import AuthManager` inside a test function (after a

```
19 | (`AuthTokens`, `AuthManager`). Each attribute access re-exports
20 | the class from `core.auth` lazily, so `from notebooklm_tools.
> 21 | services.auth import AuthManager` inside a test function (after a
22 | `monkeypatch.setattr` of `core.auth.AuthManager`) still picks up the
23 | patched class. Since we resolve the same `core.auth.X` each time,
```

Remediation:

1. Replace exec()/eval() with AST-parsed execution (ast.literal_eval for data, RestrictedPython for code). 2. Run agent code in Docker/gVisor sandbox with --no-new-privileges. 3. Use allowlist of permitted modules via importlib. 4. Add mandatory human confirmation before shell commands.

#287 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/auth.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Service layer for auth.
  2 |
  3 | Thin re-export of auth-related symbols from `core.auth` so the MCP/CLI
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#288 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/batch.py:53](#)

High-risk permission pattern: """Execute a function across multiple targets in parallel."""

```
51 |     max_concurrent: int = 5,
52 | ) -> BatchResult:
> 53 |     """Execute a function across multiple targets in parallel."""
54 |     results: list[BatchItemResult] = []
55 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#289 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/batch.py:199](#)

High-risk permission pattern: """Delete multiple notebooks.

```
197 |         max_concurrent: int = 3,  
198 |     ) -> BatchResult:  
> 199 |         """Delete multiple notebooks.  
200 |     ...  
201 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#290 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/batch.py:203](#)

High-risk permission pattern: notebook_names: Notebooks to delete

```
201 |     Args:  
202 |         client: Authenticated client  
> 203 |         notebook_names: Notebooks to delete  
204 |         tags: Select by tags  
205 |         confirm: Must be True (safety check)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#291 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/batch.py:210](#)

High-risk permission pattern: "Batch delete requires confirm=True.",

```
208 |         if not confirm:  
209 |             raise ValidationError(  
> 210 |                 "Batch delete requires confirm=True.",  
211 |                 user_message="Batch delete is IRREVERSIBLE. Set confirm=True after user approval.",  
212 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#292 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/batch.py:211](#)

High-risk permission pattern: user_message="Batch delete is IRREVERSIBLE. Set confirm=True after user approval

```
209 |         raise ValidationError(  
210 |             "Batch delete requires confirm=True.",  
> 211 |             user_message="Batch delete is IRREVERSIBLE. Set confirm=True after user approval.",  
212 |         )  
213 |
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#293 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/batch.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Batch operations service – perform operations across multiple notebooks."""
   2 | ...
   3 | from concurrent.futures import ThreadPoolExecutor, as_completed
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#294 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/chat.py:217](#)

High-risk permission pattern: """Delete the chat history for a notebook.

```
215 |     notebook_id: str,
216 | ) -> DeleteChatHistoryResult:
> 217 |     """Delete the chat history for a notebook.
    218 |
    219 |     Fetches the notebook's persistent conversation ID, then deletes
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#295 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/chat.py:236](#)

High-risk permission pattern: user_message="This notebook has no chat history to delete.",

```
234 |         raise ServiceError(
235 |             "No chat history found for this notebook.",
> 236 |             user_message="This notebook has no chat history to delete.",
    237 |         )
    238 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#296 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/chat.py:242](#)

High-risk permission pattern: raise `ServiceError(f"Failed to delete chat history: {e}")` from e

```
240 |         client.delete_chat_history(notebook_id, conv_id)
241 |     except Exception as e:
> 242 |         raise ServiceError(f"Failed to delete chat history: {e}") from e
243 | ...
244 |     return {
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#297 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/cross_notebook.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Cross-notebook query service – query multiple notebooks and aggregate results."""
  2 |
  3 | from concurrent.futures import ThreadPoolExecutor, as_completed
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#298 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/downloads.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Downloads service – shared validation and routing for artifact downloads."""
  2 |
  3 | import inspect
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#299 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/errors.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Service layer errors and exceptions."""
  2 |
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#300 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/exports.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Export service — shared business logic for Google Docs/Sheets exports."""
  2 | ...
  3 | from typing import Literal, cast
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#301 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/labels.py:275](#)

High-risk permission pattern: ""Delete one or more labels. Sources are NOT deleted.

```
273 |         label_ids: list[str],
274 |     ) -> LabelDeleteResult:
> 275 |         """Delete one or more labels. Sources are NOT deleted.
276 |
277 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#302 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/labels.py:280](#)

High-risk permission pattern: label_ids: List of label UUIDs to delete

```
278 |         client: Authenticated NotebookLM client
279 |         notebook_id: Notebook UUID
> 280 |         label_ids: List of label UUIDs to delete
281 |
282 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#303 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/labels.py:291](#)

High-risk permission pattern: "label_ids is required.", user_message="Provide at least one label ID to delete."

```
289 |         if not label_ids:
290 |             raise ValidationError(
> 291 |                 "label_ids is required.", user_message="Provide at least one label ID to delete."
292 |             )
293 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#304 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/labels.py:303](#)

High-risk permission pattern: raise `ServiceError(f"Failed to delete labels: {e}")` from e

```
301 |         result = client.delete_labels(notebook_id, clean_ids)
302 |     except Exception as e:
> 303 |         raise ServiceError(f"Failed to delete labels: {e}") from e
304 | ...
305 |     if not result:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#305 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/labels.py:306](#)

High-risk permission pattern: raise `ServiceError("Delete returned falsy result", user_message="Failed to delet`

```
304 |
305 |     if not result:
> 306 |         raise ServiceError("Delete returned falsy result", user_message="Failed to delete labels.")
307 |
308 |     count = len(clean_ids)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#306 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/labels.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Labels service – shared business logic for source label management."""
2 |
3 | from ..core.client import NotebookLMClient
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#307 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notebooks.py:312](#)

High-risk permission pattern: `"""Delete a notebook permanently.`

```
310 |         notebook_id: str,  
311 |     ) -> NotebookDeleteResult:  
> 312 |         """Delete a notebook permanently.  
313 |     ...  
314 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#308 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notebooks.py:327](#)

High-risk permission pattern: `raise ServiceError(f"Failed to delete notebook: {e}") from e`

```
325 |         result = client.delete_notebook(notebook_id)  
326 |     except Exception as e:  
> 327 |         raise ServiceError(f"Failed to delete notebook: {e}") from e  
328 |  
329 |     if result:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#309 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notebooks.py:336](#)

High-risk permission pattern: `user_message="Failed to delete notebook — no confirmation from API.",`

```
334 |         raise ServiceError(  
335 |             "Notebook deletion returned falsy result",  
> 336 |             user_message="Failed to delete notebook — no confirmation from API.",  
337 |         )  
338 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#310 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/notebooks.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Notebooks service — shared business logic for notebook CRUD and metadata operations."""  
2 |  
3 | from ..core.client import NotebookLMClient
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#311 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notes.py:179](#)

High-risk permission pattern: """Delete a note permanently.

```
177 |     note_id: str,  
178 | ) -> NoteDeleteResult:  
> 179 |     """Delete a note permanently.  
180 | ...  
181 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#312 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notes.py:195](#)

High-risk permission pattern: raise ServiceError(f"Failed to delete note: {e}") from e

```
193 |         result = client.delete_note(note_id, notebook_id)  
194 |     except Exception as e:  
> 195 |         raise ServiceError(f"Failed to delete note: {e}") from e  
196 |  
197 |     if result:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#313 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/notes.py:205](#)

High-risk permission pattern: user_message="Failed to delete note — no confirmation from API.",

```
203 |         raise ServiceError(  
204 |             "Note deletion returned falsy result",  
> 205 |             user_message="Failed to delete note — no confirmation from API.",  
206 |         )  
207 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#314 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/notes.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Notes service — shared business logic for note CRUD operations."""  
2 |  
3 | from ..core.client import NotebookLMClient
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#315 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/pipeline.py:1](#)

High-risk permission pattern: `"""Pipeline automation service — define and execute multi-step notebook workflow`

```
> 1 | """Pipeline automation service — define and execute multi-step notebook workflows."""
  2 | ...
  3 | import time
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#316 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/pipeline.py:126](#)

High-risk permission pattern: `"""Execute a single pipeline step."""`

```
124 |     params: dict,
125 | ) -> Any:
> 126 |     """Execute a single pipeline step."""
    127 |     if action == "source_add":
    128 |         source_type = params.get("type", "url")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#317 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/pipeline.py:176](#)

High-risk permission pattern: `"""Execute a pipeline by name.`

```
174 |     variables: dict[str, str] | None = None,
175 | ) -> PipelineResult:
> 176 |     """Execute a pipeline by name.
    177 |
    178 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#318 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/pipeline.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Pipeline automation service — define and execute multi-step notebook workflows."""
  2 |
  3 | import time
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#319 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Research service – shared business logic for research start, poll, and import."""
  2 | ...
  3 | import re
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#320 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/sharing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Sharing service – shared business logic for notebook sharing and collaboration."""
  2 |
  3 | import re
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#321 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/smart_select.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Smart select service – tag management and intelligent notebook selection."""
  2 |
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#322 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:500](#)

High-risk permission pattern: """Delete a source permanently.

```
498 |     source_id: str,
499 | ) -> None:
> 500 |     """Delete a source permanently.
  501 |
  502 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#323 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:513](#)

High-risk permission pattern: `f"Delete returned falsy for source {source_id}"`,

```
511 |         if not result:
512 |             raise ServiceError(
513 |                 f"Delete returned falsy for source {source_id}",
514 |                 user_message="Failed to delete source.",...
515 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#324 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:514](#)

High-risk permission pattern: `user_message="Failed to delete source."`,

```
512 |             raise ServiceError(
513 |                 f"Delete returned falsy for source {source_id}",
514 |                 user_message="Failed to delete source.",
515 |             )
516 |         except ServiceError:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#325 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:520](#)

High-risk permission pattern: `f"Failed to delete source {source_id}: {e}"`,

```
518 |         except Exception as e:
519 |             raise ServiceError(
520 |                 f"Failed to delete source {source_id}: {e}",
521 |                 user_message="Failed to delete source.",
522 |             ) from e
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#326 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:521](#)

High-risk permission pattern: `user_message="Failed to delete source."`,

```
519 |             raise ServiceError(
520 |                 f"Failed to delete source {source_id}: {e}",
521 |                 user_message="Failed to delete source.",
522 |             ) from e
523 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#327 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:529](#)

High-risk permission pattern: """Delete multiple sources permanently in a single request.

```
527 |     source_ids: list[str],
528 | ) -> None:
529 |     """Delete multiple sources permanently in a single request.
530 | ...
531 |     Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#328 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:533](#)

High-risk permission pattern: source_ids: List of source UUIDs to delete

```
531 |     Args:
532 |         client: Authenticated NotebookLM client
> 533 |         source_ids: List of source UUIDs to delete
534 |
535 |     Raises:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#329 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:540](#)

High-risk permission pattern: raise ValidationError("No source IDs provided for bulk delete.")

```
538 |     """
539 |     if not source_ids:
> 540 |         raise ValidationError("No source IDs provided for bulk delete.")
541 |
542 |     try:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#330 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:546](#)

High-risk permission pattern: `f"Bulk delete returned falsy for {len(source_ids)} sources",`

```
544 |         if not result:
545 |             raise ServiceError(
> 546 |                 f"Bulk delete returned falsy for {len(source_ids)} sources",
547 |                 user_message="Failed to delete sources.",...
548 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#331 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:547](#)

High-risk permission pattern: `user_message="Failed to delete sources.",`

```
545 |             raise ServiceError(
546 |                 f"Bulk delete returned falsy for {len(source_ids)} sources",
> 547 |                 user_message="Failed to delete sources.",
548 |             )
549 |         except (ValidationError, ServiceError):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#332 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:553](#)

High-risk permission pattern: `f"Failed to delete {len(source_ids)} sources: {e}",`

```
551 |         except Exception as e:
552 |             raise ServiceError(
> 553 |                 f"Failed to delete {len(source_ids)} sources: {e}",
554 |                 user_message="Failed to delete sources.",
555 |             ) from e
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#333 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/sources.py:554](#)

High-risk permission pattern: `user_message="Failed to delete sources.",`

```
552 |             raise ServiceError(
553 |                 f"Failed to delete {len(source_ids)} sources: {e}",
> 554 |                 user_message="Failed to delete sources.",
555 |             ) from e
556 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#334 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/services/sources.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Sources service – shared validation and logic for source management."""
   2 | ...
   3 | import urllib.parse
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#335 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/services/sources.py:3](#)

Dynamic HTTP with sensitive data context

```
> 1 | """Sources service – shared validation and logic for source management."""
   2 |
   3 | import urllib.parse
   4 | from typing import Any
   5 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#336 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/services/sources.py:150](#)

Dynamic HTTP with sensitive data context

```
> 148 |         if not url:
   149 |             raise ValidationError("url is required for source_type='url'")
   150 |         parsed = urllib.parse.urlparse(url)
   151 |         if not parsed.scheme or parsed.scheme.lower() not in ALLOWED_URL_SCHEMES:
   152 |             raise ValidationError(
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#337 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:1](#)

High-risk permission pattern: `"""Studio service — artifact creation, status, rename, delete.`

```
> 1 | """Studio service — artifact creation, status, rename, delete.  
  2 | ...  
  3 | Centralizes:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#338 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:751](#)

High-risk permission pattern: `# ----- Delete -----`

```
749 |  
750 |  
> 751 | # ----- Delete -----  
752 |  
753 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#339 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:759](#)

High-risk permission pattern: `"""Delete a studio artifact permanently.`

```
757 |     notebook_id: str,  
758 | ) -> None:  
> 759 |     """Delete a studio artifact permanently.  
760 |  
761 |     Raises:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#340 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:768](#)

High-risk permission pattern: `f"Delete returned falsy for artifact {artifact_id}",`

```
766 |         if not result:  
767 |             raise ServiceError(  
> 768 |                 f"Delete returned falsy for artifact {artifact_id}",  
769 |                 user_message="Failed to delete artifact.",  
770 |             )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#341 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:769](#)

High-risk permission pattern: `user_message="Failed to delete artifact."`,

```
767 |         raise ServiceError(  
768 |             f"Delete returned falsy for artifact {artifact_id}",  
> 769 |             user_message="Failed to delete artifact.",  
770 |         )...  
771 |     except ServiceError:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#342 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:775](#)

High-risk permission pattern: `f"Failed to delete artifact: {e}"`,

```
773 |     except Exception as e:  
774 |         raise ServiceError(  
> 775 |             f"Failed to delete artifact: {e}",  
776 |             user_message="Could not delete artifact.",  
777 |         ) from e
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#343 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/services/studio.py:776](#)

High-risk permission pattern: `user_message="Could not delete artifact."`,

```
774 |         raise ServiceError(  
775 |             f"Failed to delete artifact: {e}",  
> 776 |             user_message="Could not delete artifact.",  
777 |         ) from e  
778 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#344 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/utils/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Utility functions shared across the package."""  
2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#345 AS-007 -- SUPPLY CHAIN

LOW

OWASP: AA-06 | MITRE: T1195 | STRIDE: Tampering

External dependencies without integrity verification or lockfiles

[src/notebooklm_tools/utils/auth_browser.py:56](#)

Dependency without integrity verification

```
54 |         raise AuthenticationError(  
55 |             message="No supported browser found",  
> 56 |             hint=f"Install {browser_text}, or use 'nrm login --manual' to import cookies from a  
file.",  
57 |         )...  
58 |
```

Remediation:

1. Use lockfiles (package-lock.json, poetry.lock, requirements.txt with hashes). 2. Pin exact dependency versions — never use >= or latest. 3. Run npm audit / pip-audit in CI. 4. Use pip install --require-hashes for Python. 5. Verify package signatures where available.

#346 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/utils/auth_browser.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Browser/backend selection for interactive and headless authentication."""  
2 |  
3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#347 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/utils/browser.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Browser cookie utilities."""  
2 |  
3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#348 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/utils/cdp.py:865](#)

High-risk permission pattern: """Execute a CDP command via WebSocket.

```
863 |         ws_url: str, method: str, params: dict | None = None, *, retry: bool = True  
864 |     ) -> dict:  
> 865 |         """Execute a CDP command via WebSocket.  
866 |  
867 |         Args:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#349 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/utils/cdp.py:1096](#)

High-risk permission pattern: clear_profile: If True, delete the Chrome user-data-dir before launching

```
1094 |         login_timeout: Max seconds to wait for login
1095 |         profile_name: NLM profile name (each gets its own Chrome user-data-dir)
> 1096 |         clear_profile: If True, delete the Chrome user-data-dir before launching
1097 | ...
1098 |     Returns:
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#350 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/utils/cdp.py:1150](#)

High-risk permission pattern: hint=f"Close any stuck browser processes or delete the SingletonLock file in the

```
1148 |         raise AuthenticationError(
1149 |             message="The NLM auth profile is locked but no browser instance was found",
> 1150 |             hint=f"Close any stuck browser processes or delete the SingletonLock file in the
{profile_name} browser profile.",
1151 |         )
1152 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#351 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/utils/cdp.py:163](#)

File input near prompt/instruction handling — injection vector

```
161 |     map_file = _get_port_map_file()
162 |     try:
> 163 |         fd = os.open(str(map_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
164 |         try:
165 |             f = os.fdopen(fd, "w", encoding="utf-8")
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#352 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/utils/cdp.py:165](#)

File input near prompt/instruction handling — injection vector

```
163 |         fd = os.open(str(map_file), os.O_WRONLY | os.O_CREAT | os.O_TRUNC, 0o600)
164 |         try:
> 165 |             f = os.fdopen(fd, "w", encoding="utf-8")
166 |         except BaseException:
167 |             os.close(fd)
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#353 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/utils/cdp.py:650](#)

File input near prompt/instruction handling — injection vector

```
648 |         try:
649 |             _logger.debug("Launching browser: %s on port %d", chrome_path, port)
> 650 |             process = subprocess.Popen(args, **kwargs) # nsec B603 – chrome_path from shutil.which();
args built from hardcoded flags + validated port
651 |             return process
652 |         except Exception as e:
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#354 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/utils/cdp.py:21](#)

Dynamic HTTP with sensitive data context

```
19 | from pathlib import Path
20 | from typing import Any
> 21 | from urllib.parse import quote, urlparse
22 |
23 | from httpx import Client, HTTPTransport
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#355 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/utils/config.py:60](#)

Dynamic HTTP with sensitive data context

```
58 |     """
59 |     url = os.environ.get("NOTEBOOKLM_BASE_URL", "https://notebooklm.google.com").rstrip("/")
> 60 |     from urllib.parse import urlparse
61 |
62 |     parsed = urlparse(url)
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#356 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[src/notebooklm_tools/utils/io_encoding.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Normalize stdio text encoding where platform defaults break Unicode (Windows).
  2 | ...
  3 | Windows consoles often default to cp1252. Typer/Rich then raise UnicodeEncodeError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#357 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/utils/wsl.py:191](#)

High-risk permission pattern: "\n 2. Run: taskkill /f /im chrome.exe (in Windows PowerShell Admin)"

```
189 |                                     "\n\nPlease:"
190 |                                     "\n 1. Close ALL Chrome windows and tabs manually"
> 191 |                                     "\n 2. Run: taskkill /f /im chrome.exe (in Windows PowerShell Admin)"
192 |                                     "\n 3. Then retry: nlm login --wsl"
193 |                                     )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#358 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[src/notebooklm_tools/utils/wsl.py:458](#)

High-risk permission pattern: # This will trigger UAC prompt if not running as admin

```
456 |     try:
457 |         # Build PowerShell command to create firewall rule
> 458 |         # This will trigger UAC prompt if not running as admin
459 |         logger.info(f"Creating Windows Firewall rule for port {port}")
460 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#359 AS-004 -- PROMPT INJECTION

HIGH

OWASP: AA-02 | MITRE: T1190 | STRIDE: Tampering

File input flows near prompt or instruction handling create injection vectors

[src/notebooklm_tools/utils/wsl.py:279](#)

File input near prompt/instruction handling — injection vector

```
277 |     logger.debug(f"Chrome temp profile: {temp_dir}")
278 |     try:
> 279 |         process = subprocess.Popen( # nsec B603 B607 — args built from validated Chrome path +
hardcoded flags + int port
280 |             args,...
281 |             stdout=stdout_arg,
```

Remediation:

1. Sanitize all file contents before injecting into prompts (strip control chars, limit length). 2. Use structured input schemas — never concatenate raw file content into system prompts. 3. Implement input/output firewalls (Rebuff, LLM Guard). 4. Separate data plane from control plane in prompt construction.

#360 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/utils/wsl.py:306](#)

Dynamic HTTP with sensitive data context

```
304 |     """ True if CDP is ready, False if timeout.
305 |     """
> 306 |     import urllib.parse
307 |
308 |     parsed = urllib.parse.urlparse(cdp_url)
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#361 AS-011 -- DATA EXFILTRATION

HIGH

OWASP: AA-10 | MITRE: T1041 | STRIDE: Information Disclosure

Dynamic HTTP requests that could exfiltrate sensitive data to attacker-controlled endpoints

[src/notebooklm_tools/utils/wsl.py:308](#)

Dynamic HTTP with sensitive data context

```
306 |     import urllib.parse
307 |
> 308 |     parsed = urllib.parse.urlparse(cdp_url)
309 |     base_url = f"{parsed.scheme}://{parsed.hostname}:{parsed.port}"
310 |
```

Remediation:

1. Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains. 2. Use egress firewalls or network policies to restrict outbound traffic. 3. Redact sensitive data (tokens, credentials) before passing to agent context. 4. Log all outbound HTTP requests with destination and payload size. 5. Block requests containing sensitive patterns in the body.

#362 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_formatters.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | import json
2 | from types import SimpleNamespace
3 | from unittest.mock import patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#363 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/cli/test_login.py:1`

No logging, auditing, or monitoring detected

```
> 1 | from types import SimpleNamespace
  2 | ...
  3 | from typer.testing import CliRunner
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#364 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/cli/test_repl.py:1`

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the interactive chat REPL."""
  2 |
  3 | from contextlib import nullcontext
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#365 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

`tests/cli/test_setup_github_copilot.py:1`

No logging, auditing, or monitoring detected

```
> 1 | """Tests for GitHub Copilot support in ``nlm setup add/remove/list``."""
  2 |
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#366 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_setup_opencode.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for OpenCode client support in `nlm setup add/remove/list`.
  2 | ...
  3 | Verifies that the OpenCode integration correctly handles the different
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#367 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_source_add.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the `nlm source add` CLI command, focusing on --youtube bulk support."""
  2 |
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#368 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_studio_cli.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the `nlm slides revise` CLI command."""
  2 |
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#369 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_verbs_defaults.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests that verb command fallback defaults match valid CodeMapper values.
  2 |
  3 | Verbs in verbs.py use `xxx` or "fallback" patterns to provide defaults
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#370 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/cli/test_verbs_parity.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Test that verb wrappers pass all parameters their target functions accept.
  2 | ...
  3 | When a verb wrapper calls a target function directly (not through Typer),
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#371 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_alias.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for alias type detection."""
  2 |
  3 | from contextlib import nullcontext
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#372 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_auth_check.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Test-driven development for the elegant unified auth validity check.
  2 |
  3 | The goal is a single source of truth:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#373 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_auth_guard.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for account mismatch guard in profile saving."""
  2 |
  3 | from notebooklm_tools.core.exceptions import AccountMismatchError, NLModelError
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#374 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_base.py:33](#)

Potential secret: possible hardcoded secret

```
31 | # When csrf_token is provided, _refresh_auth_tokens should NOT be called
32 | with patch.object(BaseClient, "_refresh_auth_tokens") as mock_refresh:
> 33 |     client = BaseClient(cookies={"test": "cookie"}, csrf_token="test_token")
34 |     mock_refresh.assert_not_called()...
35 |     assert client.csrf_token == "test_token"
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#375 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_base.py:43](#)

Potential secret: possible hardcoded secret

```
41 |
42 | with patch.object(BaseClient, "_refresh_auth_tokens"):
> 43 |     client = BaseClient(cookies={}, csrf_token="test_token")
44 |     body = client._build_request_body("testRpc", ["param1"])
45 |     assert "f.req=" in body
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#376 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_base.py:55](#)

Potential secret: possible hardcoded secret

```
53 |
54 | with patch.object(BaseClient, "_refresh_auth_tokens"):
> 55 |     client = BaseClient(cookies={}, csrf_token="test_token", session_id="test_sid")
56 |     url = client._build_url("testRpc", "/notebook/123")
57 |     assert "rpcids=testRpc" in url
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#377 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_base.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | # tests/core/test_base.py
2 | """Tests for BaseClient infrastructure class."""
3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#378 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_data_types.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from notebooklm_tools.core.data_types import (  
  2 |     Collaborator,...  
  3 |     ConversationTurn,
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#379 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_download.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3  
  2 | """Tests for DownloadMixin."""  
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#380 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_errors.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | # tests/core/test_errors.py  
  2 | """Tests for artifact exception classes."""  
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#381 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_notebooks.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for NotebookMixin class."""  
  2 |  
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#382 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_notes.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for NotesMixin class."""
  2 | ...
  3 | from unittest.mock import patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#383 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
  2 | """Tests for ResearchMixin."""
  3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#384 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_retry.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from unittest.mock import Mock, patch
  2 |
  3 | import httpx
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#385 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_sharing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for SharingMixin class."""
  2 |
  3 | from unittest.mock import patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#386 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_source_reconciliation.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for source reconciliation logic (Issue #196).
    2 | ...
    3 | Verifies that accepted-pending RPC errors (code 3 / code 9) are resolved
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#387 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_sources.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for SourceMixin class."""
    2 |
    3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#388 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_studio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
    2 | """Tests for StudioMixin."""
    3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#389 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/core/test_thread_safety.py:19](#)

Potential secret: possible hardcoded secret

```
> 17 |
    18 |     with patch.object(BaseClient, "_refresh_auth_tokens"):
    19 |         return NotebookLMClient(cookies={"test": "cookie"}, csrf_token="test_token")
    20 |
    21 |
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#390 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_thread_safety.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | # tests/core/test_thread_safety.py
   2 | """Tests for thread-safety of NotebookLMClient shared state...
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#391 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_url_source_fallback.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for dual RPC fallback in URL source addition (issue #121).
   2 |
   3 | These tests exercise the core layer's add_url_source and add_url_sources
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#392 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/core/test_utils.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from notebooklm_tools.core.utils import (
   2 |     RPC_NAMES,
   3 |     extract_cookies_from_chrome_export,
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#393 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/manual/test_fastmcp_stdio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | import asyncio
   2 | import sys
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#394 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/manual/test_revise_slide_deck.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | #!/usr/bin/env python3
   2 | """Manual test: Revise a slide deck via RPC KmckPe....
   3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#395 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/__init__.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the services layer."""
   2 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#396 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[tests/services/test_auth_service.py:141](#)

Dangerous execution: `exec("from notebooklm_tools.services.auth import AuthManager", local_namespace)`

```
139 | # Re-execute the import statement the same way cli code does.
140 | local_namespace = {}
> 141 | exec("from notebooklm_tools.services.auth import AuthManager", local_namespace)
142 | assert local_namespace["AuthManager"] is sentinel_class
143 |
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#397 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_auth_service.py:139](#)

High-risk permission pattern: # Re-execute the import statement the same way cli code does.

```
137 |
138 | monkeypatch.setattr(core_auth, "AuthManager", sentinel_class, raising=True)
> 139 | # Re-execute the import statement the same way cli code does.
140 | local_namespace = {}
141 | exec("from notebooklm_tools.services.auth import AuthManager", local_namespace)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#398 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_auth_service.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for the services.auth re-export shim.
  2 | ...
  3 | The shim exists to satisfy the layering rule (cli/ and mcp/ must not import
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#399 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_batch.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for batch service – batch operations across notebooks."""
  2 |
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#400 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_chat.py:181](#)

High-risk permission pattern: with pytest.raises(ServiceError, match="Failed to delete"):

```
179 |         mock_client.delete_chat_history.side_effect = RuntimeError("server error")
180 |
> 181 |         with pytest.raises(ServiceError, match="Failed to delete"):
182 |             delete_chat_history(mock_client, "nb-123")
183 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#401 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_chat.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.chat module."""
  2 |
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#402 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_cross_notebook.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for cross_notebook service – cross-notebook queries."""
  2 | ...
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#403 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_downloads.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.downloads module."""
  2 |
  3 | from unittest.mock import AsyncMock, MagicMock
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#404 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_errors.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.errors module."""
  2 |
  3 | import pytest
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#405 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_exports.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.exports module."""
  2 |
  3 | from unittest.mock import MagicMock
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#406 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_notebooks.py:224](#)

High-risk permission pattern: with `pytest.raises(ServiceError, match="Failed to delete notebook")`:

```
222 |         def test_api_error_raises_service_error(self, mock_client):
223 |             mock_client.delete_notebook.side_effect = RuntimeError("fail")
> 224 |             with pytest.raises(ServiceError, match="Failed to delete notebook"):
225 |                 delete_notebook(mock_client, "nb-123")...
226 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#407 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_notebooks.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.notebooks module."""
2 |
3 | from types import SimpleNamespace
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#408 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_notes.py:156](#)

High-risk permission pattern: with `pytest.raises(ServiceError, match="Failed to delete note")`:

```
154 |         def test_api_error_raises_service_error(self, mock_client):
155 |             mock_client.delete_note.side_effect = RuntimeError("fail")
> 156 |             with pytest.raises(ServiceError, match="Failed to delete note"):
157 |                 delete_note(mock_client, "nb-123", "note-1")
158 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#409 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_notes.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.notes module."""
2 |
3 | from unittest.mock import MagicMock
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#410 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_pipeline.py:197](#)

High-risk permission pattern: `(pipeline_dir / "delete-test.yaml").write_text(`

```
195 |         pipeline_dir = pipelines_dir / "pipelines"
196 |         pipeline_dir.mkdir(parents=True, exist_ok=True)
> 197 |         (pipeline_dir / "delete-test.yaml").write_text(
198 |             yaml.dump(...)
199 |         )
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#411 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_pipeline.py:200](#)

High-risk permission pattern: `"name": "delete-test",`

```
198 |         yaml.dump(
199 |             {
> 200 |                 "name": "delete-test",
201 |                 "steps": [{"action": "notebook_delete", "params": {}}],
202 |             }
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#412 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_pipeline.py:206](#)

High-risk permission pattern: `result = pipeline_run(mock_client, "nb-001", "delete-test")`

```
204 |         )
205 |
> 206 |         result = pipeline_run(mock_client, "nb-001", "delete-test")
207 |         assert result["succeeded"] == 1
208 |         mock_notebooks.delete_notebook.assert_called_once_with(mock_client, "nb-001")
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#413 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_pipeline.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for pipeline service – multi-step workflow automation."""
2 |
3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#414 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_research.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.research module."""
  2 | ...
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#415 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sharing.py:148](#)

High-risk permission pattern: `invite_collaborator(mock_client, "nb-123", "alice@example.com", "admin")`

```
146 |     def test_invalid_role_raises_validation_error(self, mock_client):
147 |         with pytest.raises(ValidationError, match="Invalid role"):
> 148 |             invite_collaborator(mock_client, "nb-123", "alice@example.com", "admin")
149 |
150 |     def test_role_case_insensitive(self, mock_client):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#416 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sharing.py:201](#)

High-risk permission pattern: `{"email": "alice@example.com", "role": "admin"}`,

```
199 |     def test_invalid_role_raises_validation_error(self, mock_client):
200 |         recipients = [
> 201 |             {"email": "alice@example.com", "role": "admin"},
202 |         ]
203 |         with pytest.raises(ValidationError, match="Invalid role"):
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#417 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_sharing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.sharing module."""
  2 |
  3 | from dataclasses import dataclass
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#418 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_smart_select.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for smart_select service – tag management and intelligent notebook selection."""
    2 | ...
    3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#419 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sources.py:43](#)

High-risk permission pattern: # Sync/delete/describe/content

```
> 41 | ]
    42 | client.check_source_freshness.return_value = True
    43 | # Sync/delete/describe/content
    44 | client.sync_drive_source.return_value = True
    45 | client.delete_source.return_value = True
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#420 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sources.py:296](#)

High-risk permission pattern: with pytest.raises(ServiceError, match="Delete returned falsy"):

```
> 294 | def test_falsy_result_raises(self, mock_client):
    295 |     mock_client.delete_source.return_value = False
    296 |     with pytest.raises(ServiceError, match="Delete returned falsy"):
    297 |         delete_source(mock_client, "src-1")
    298 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#421 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sources.py:301](#)

High-risk permission pattern: with pytest.raises(ServiceError, match="Failed to delete"):

```
> 299 | def test_api_error(self, mock_client):
    300 |     mock_client.delete_source.side_effect = RuntimeError("fail")
    301 |     with pytest.raises(ServiceError, match="Failed to delete"):
    302 |         delete_source(mock_client, "src-1")
    303 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#422 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sources.py:457](#)

High-risk permission pattern: with `pytest.raises(ServiceError, match="Bulk delete returned falsy")`:

```
455 |         def test_falsy_result_raises(self, mock_client):
456 |             mock_client.delete_sources.return_value = False
> 457 |             with pytest.raises(ServiceError, match="Bulk delete returned falsy"):
458 |                 delete_sources(mock_client, ["s1"])...
459 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#423 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_sources.py:462](#)

High-risk permission pattern: with `pytest.raises(ServiceError, match="Failed to delete")`:

```
460 |         def test_api_error(self, mock_client):
461 |             mock_client.delete_sources.side_effect = RuntimeError("fail")
> 462 |             with pytest.raises(ServiceError, match="Failed to delete"):
463 |                 delete_sources(mock_client, ["s1"])
464 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#424 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_sources.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.sources module."""
2 |
3 | from unittest.mock import MagicMock
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#425 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_studio.py:57](#)

High-risk permission pattern: # Rename/delete

```
55 |         {"mind_map_id": "mm-1", "title": "Map 1"},
56 |     ]
> 57 |     # Rename/delete
58 |     client.rename_studio_artifact.return_value = True...
59 |     client.delete_studio_artifact.return_value = True
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#426 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_studio.py:454](#)

High-risk permission pattern: with pytest.raises(ServiceError, match="Delete returned falsy"):

```
452 |     def test_falsy_result(self, mock_client):
453 |         mock_client.delete_studio_artifact.return_value = False
> 454 |         with pytest.raises(ServiceError, match="Delete returned falsy"):
455 |             delete_artifact(mock_client, "art-1", "nb-1")
456 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#427 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/services/test_studio.py:459](#)

High-risk permission pattern: with pytest.raises(ServiceError, match="Failed to delete"):

```
457 |     def test_api_error(self, mock_client):
458 |         mock_client.delete_studio_artifact.side_effect = RuntimeError("fail")
> 459 |         with pytest.raises(ServiceError, match="Failed to delete"):
460 |             delete_artifact(mock_client, "art-1", "nb-1")
461 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#428 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/services/test_studio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for services.studio module."""
2 |
3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#429 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_api_client.py:14](#)

Potential secret: possible hardcoded secret

```
12 |     cookies = {"SID": "test_sid"}
13 |     with patch.object(NotebookLMClient, "_refresh_auth_tokens"):
> 14 |         client = NotebookLMClient(cookies=cookies, csrf_token="old_token", session_id="old_sid")
15 |         return client...
16 |
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#430 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_api_client.py:105](#)

High-risk permission pattern: # Execute

```
103 |         ]
104 |
> 105 |         # Execute
106 |         result = mock_client._call_rpc("rLM1Ne", [])
107 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#431 AS-005 -- INJECTION PATTERN

CRITICAL

OWASP: AA-02 | MITRE: T1055 | STRIDE: Tampering

Known prompt injection, SQL injection, XSS, or command injection patterns

[tests/test_api_client.py:119](#)

Known injection pattern detected

```
117 |         # Simplified HTML to minimize whitespace issues
118 |         # api_client.py looks for "FdrFJe": "." for the session ID
> 119 |         html = '<html><script>WIZ_global_data = {"SNlM0e": "new_csrf_token", "FdrFJe": "123456789"};</
script></html>'
120 |
121 |         # Restore the original method for this test
```

Remediation:

1. Validate and sanitize all inputs with strict allowlists. 2. Use parameterized queries for any database access (never string concatenation). 3. HTML-encode all agent output before rendering. 4. Implement content security policy (CSP) headers. 5. Block known injection patterns at the input boundary.

#432 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_api_client.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | import json
2 | from unittest.mock import MagicMock, patch
3 |
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#433 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_auth_browser.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for supported authentication browser behavior."""
  2 | ...
  3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#434 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_auth_migration.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests to validate auth works after removing notebooklm-mcp-auth.
  2 |
  3 | These tests verify that:
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#435 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_cdp_proxy_bypass.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """CDP WebSocket must not use HTTP*_PROXY for localhost (Issue #119, PR #157)."""
  2 |
  3 | import os
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#436 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_cdp_url_check.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for ``is_logged_in()`` URL detection.
  2 | ...
  3 | Background: ``is_logged_in(url)`` previously used a substring match
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#437 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_coerce_list.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for MCP tools coerce_list utility."""
  2 |
  3 | from notebooklm_tools.mcp.tools._utils import coerce_list
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#438 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:17](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".json", delete=False) as f:

```
15 | def test_parse_json_dict():
16 |     """JSON dict format: {"name": "value"}."""
> 17 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".json", delete=False) as f:
18 |         json.dump({"SID": "abc123", "HSID": "def456"}, f)
19 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#439 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:46](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
44 | def test_parse_netscape_format():
45 |     """Netscape cookie file with tab-separated fields."""
> 46 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
47 |         f.write(SAMPLE_NETSCAPE)
48 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#440 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:68](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
66 | from notebooklm_tools.utils.browser import validate_notebooklm_cookies
67 |
> 68 | with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
69 |     f.write(SAMPLE_NETSCAPE)...
70 |     path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#441 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:86](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
84 |
85 | ""
> 86 | with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
87 |     f.write(content)
88 |     path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#442 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:99](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
97 | """Content with tabs but not 7+ fields per line falls through."""
98 | content = "just\ta\tfew\tfields\nnot\tenough"
> 99 | with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
100 |     f.write(content)
101 |     path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#443 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:114](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
112 | def test_parse_cookie_header():
113 |     """Standard Cookie header format."""
> 114 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
115 |         f.write("Cookie: SID=abc; HSID=def; SSID=ghi")
116 |         path = f.name
```


Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#444 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:126](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
124 | def test_parse_name_value_pairs():
125 |     """Plain name=value pairs separated by semicolons."""
> 126 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
127 |         f.write("SID=abc; HSID=def; SSID=ghi")...
128 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#445 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:150](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
148 |         "#HttpOnly_.google.com\tTRUE\t/\tTRUE\t1812953356\t__Secure-1PSIDTS\tsecure-value-123\n"
149 |     )
> 150 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
151 |         f.write(content)
152 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#446 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:166](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
164 |         "#HttpOnly_.google.com\tTRUE\t/\tTRUE\t1812953356\t__Secure-3PSIDTS\tsecure-value\n"
165 |     )
> 166 |     with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
167 |         f.write(content)
168 |         path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#447 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:179](#)

High-risk permission pattern: with `tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False)` as f:

```
177 | """Cookies with empty values should be parsed with an empty string value."""
178 | content = ".google.com\tTRUE\t\tFALSE\t1812953356\tEMPTY_COOKIE\t\n"
> 179 | with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
180 |     f.write(content)...
181 |     path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#448 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_cookie_parsing.py:192](#)

High-risk permission pattern: with `tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False)` as f:

```
190 | """Cookie values that contain tabs internally are joined and parsed fully."""
191 | content = ".google.com\tTRUE\t\tFALSE\t1812953356\tTAB_COOKIE\tvalue\twith\t\tabs\n"
> 192 | with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
193 |     f.write(content)
194 |     path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#449 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_cookie_parsing.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for cookie parsing from files (Netscape format support)."""
2 |
3 | import json
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#450 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_download_integration.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Integration tests for Download functionalities.
2 |
3 | Targeting Notebook: 4085e211-fdb0-4802-b973-b43b9f99b6f7
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#451 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_e2e.py:66](#)

High-risk permission pattern: notebook = client.create_notebook(title="E2E Delete Test")

```
64 |         """Test creating and deleting a notebook."""
65 |         # Create
66 |         notebook = client.create_notebook(title="E2E Delete Test")
67 |         assert notebook is not None...
68 |         assert notebook.id is not None
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#452 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_e2e.py:69](#)

High-risk permission pattern: assert "E2E Delete Test" in notebook.title

```
67 |         assert notebook is not None
68 |         assert notebook.id is not None
69 |         assert "E2E Delete Test" in notebook.title
70 |
71 |         # Delete
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#453 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_e2e.py:71](#)

High-risk permission pattern: # Delete

```
69 |         assert "E2E Delete Test" in notebook.title
70 |
71 |         # Delete
72 |         result = client.delete_notebook(notebook.id)
73 |         assert result is True
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#454 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_e2e.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """End-to-end tests for NotebookLM Tools.
2 |
3 | These tests run against the real NotebookLM API using cached credentials.
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#455 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:94](#)

Potential secret: possible hardcoded secret

```
92 |         client = SourceMixin.__new__(SourceMixin)
93 |         client.cookies = {"test": "cookie"}
> 94 |         client.csrf_token = "test-csrf"
95 |         client._session_id = "test-session"...
96 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#456 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:119](#)

Potential secret: possible hardcoded secret

```
117 |         client = SourceMixin.__new__(SourceMixin)
118 |         client.cookies = {"test": "cookie"}
> 119 |         client.csrf_token = "test-csrf"
120 |         client._session_id = "test-session"
121 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#457 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:142](#)

Potential secret: possible hardcoded secret

```
140 |         client = SourceMixin.__new__(SourceMixin)
141 |         client.cookies = {"test": "cookie"}
> 142 |         client.csrf_token = "test-csrf"
143 |         client._session_id = "test-session"
144 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#458 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:173](#)

Potential secret: possible hardcoded secret

```
171 |         client = SourceMixin.__new__(SourceMixin)
172 |         client.cookies = {"test": "cookie"}
> 173 |         client.csrf_token = "test-csrf"
174 |         client._session_id = "test-session"
175 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#459 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:203](#)

Potential secret: possible hardcoded secret

```
201 |         client = SourceMixin.__new__(SourceMixin)
> 202 |         client.cookies = {"test": "cookie"}
    203 |         client.csrf_token = "test-csrf"
    204 |         client._session_id = "test-session"...
    205 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#460 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:243](#)

Potential secret: possible hardcoded secret

```
241 |         client = SourceMixin.__new__(SourceMixin)
> 242 |         client.cookies = {"test": "cookie"}
    243 |         client.csrf_token = "test-csrf"
    244 |         client._session_id = "test-session"
    245 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#461 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_file_upload.py:282](#)

Potential secret: possible hardcoded secret

```
280 |         client = SourceMixin.__new__(SourceMixin)
> 281 |         client.cookies = {"test": "cookie"}
    282 |         client.csrf_token = "test-csrf"
    283 |         client._session_id = "test-session"
    284 |         client._client = None
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#462 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:40](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(suffix=".txt", delete=False) as f:

```
38 |         client._client = None
39 |
> 40 |         with tempfile.NamedTemporaryFile(suffix=".txt", delete=False) as f:
41 |             temp_path = f.name...
42 |
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#463 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:74](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".json", delete=False) as f:

```
72 |
73 |         # Create a JSON file (unsupported type)
> 74 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".json", delete=False) as f:
75 |             f.write('{"test": "data"}')
76 |             temp_path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#464 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:208](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
206 |
207 |         # Create a temporary test file
> 208 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
209 |             f.write("Test content for upload")
210 |             temp_path = Path(f.name)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#465 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:248](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
246 |
247 |         # Create a test file
> 248 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
249 |             f.write("Test content")
250 |             temp_path = Path(f.name)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#466 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:286](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="wb", suffix=".epub", delete=False) as f:

```
284 |         client._client = None
> 285 |
286 |         with tempfile.NamedTemporaryFile(mode="wb", suffix=".epub", delete=False) as f:
287 |             f.write(b"PK\x03\x04fake epub content")...
288 |             temp_path = Path(f.name)
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#467 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_file_upload.py:330](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
328 |         )
> 329 |
330 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
331 |             f.write("Test content for NotebookLM upload.")
332 |             temp_path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#468 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_file_upload.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for file upload functionality."""
2 |
3 | import tempfile
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#469 AS-001 -- UNSAFE EXECUTION

CRITICAL

OWASP: AA-03 | MITRE: T1059 | STRIDE: Elevation of Privilege

Dangerous code execution patterns that allow arbitrary command injection

[tests/test_io_encoding_windows.py:37](#)

Dangerous execution: with `__import__("pytest").raises(UnicodeEncodeError):`

```
35 |  
36 |     stream = io.TextIOWrapper(io.BytesIO(), encoding="cp1252", errors="strict")  
> 37 |     with __import__("pytest").raises(UnicodeEncodeError):  
38 |         stream.write("\u2192")...  
39 |
```

Remediation:

1. Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code). 2. Run agent code in Docker/gVisor sandbox with `--no-new-privileges`. 3. Use allowlist of permitted modules via `importlib`. 4. Add mandatory human confirmation before shell commands.

#470 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_io_encoding_windows.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Windows stdio UTF-8 bootstrap (Issue #156)."""  
2 |  
3 | import sys
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#471 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_auth_studio_failures.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Regression tests for the P1 auth/studio silent-failure bug (Netter bug report 2026-06-01).  
2 |  
3 | Bug: under stale/expired auth, `refresh_auth()` returns status:"success" (it only
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include `agent_id`, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#472 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_mcp_e2e.py:78](#)

High-risk permission pattern: `result = mcp_tools["notebooks"].notebook_create(title="MCP Delete Test")`

```
76 |  
77 |     """Test full notebook lifecycle."""  
> 78 |     # Create  
79 |     result = mcp_tools["notebooks"].notebook_create(title="MCP Delete Test")  
80 |     assert result["status"] == "success"  
    notebook_id = result["notebook_id"]
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#473 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_mcp_e2e.py:86](#)

High-risk permission pattern: # Delete

```
84 |         assert result["status"] == "success"
85 |
> 86 |         # Delete
87 |         result = mcp_tools["notebooks"].notebook_delete(notebook_id, confirm=True)...
88 |         assert result["status"] == "success"
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#474 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_e2e.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """End-to-end tests for MCP Server Tools.
2 |
3 | Tests the consolidated MCP tools against the real NotebookLM API.
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#475 AS-003 -- EXCESSIVE PERMISSIONS

MEDIUM

OWASP: AA-04 | MITRE: T1078 | STRIDE: Elevation of Privilege

Agent requests high-risk permissions beyond minimum necessary

[tests/test_mcp_file_upload.py:23](#)

High-risk permission pattern: with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:

```
21 |
22 |         # Create a test file
> 23 |         with tempfile.NamedTemporaryFile(mode="w", suffix=".txt", delete=False) as f:
24 |             f.write("Test content")
25 |             temp_path = f.name
```

Remediation:

1. Apply principle of least privilege — grant only permissions the agent needs for its specific task. 2. Use scoped API tokens (read-only where possible). 3. Implement permission escalation flow requiring human approval. 4. Audit permission usage and revoke unused grants.

#476 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_file_upload.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for MCP file upload functionality via consolidated source_add."""
2 |
3 | import tempfile
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#477 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_mcp_studio.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Unit tests for MCP studio tools."""
  2 | ...
  3 | from unittest.mock import MagicMock, patch
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#478 AS-002 -- SECRET SCAN

HIGH

OWASP: AA-05 | MITRE: T1552 | STRIDE: Information Disclosure

Hardcoded secrets, API keys, tokens, or credentials in source code

[tests/test_research_polling.py:12](#)

Potential secret: possible hardcoded secret

```
10 |     cookies = {"SID": "test_sid"}
11 |     with patch.object(NotebookLMClient, "_refresh_auth_tokens"):
> 12 |         client = NotebookLMClient(cookies=cookies, csrf_token="old_token", session_id="old_sid")
13 |         return client
14 |
```

Remediation:

1. Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv). 2. Add pre-commit hooks (detect-secrets, trufflehog) to block secret commits. 3. Rotate any exposed keys immediately. 4. Add .env to .gitignore.

#479 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_research_polling.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | from unittest.mock import patch
  2 |
  3 | import pytest
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

#480 AS-010 -- LOGGING MONITORING

MEDIUM

OWASP: AA-08 | MITRE: T1562.002 | STRIDE: Repudiation

No evidence of logging, auditing, or monitoring in agent code

[tests/test_snap.py:1](#)

No logging, auditing, or monitoring detected

```
> 1 | """Tests for snap browser detection and profile directory routing."""
  2 |
  3 | from pathlib import Path
```

Remediation:

1. Add structured logging (JSON) for every agent action, tool call, and decision. 2. Include agent_id, timestamp, action, parameters, and outcome in each log entry. 3. Ship logs to a centralized SIEM (Splunk, Elastic, Sentinel). 4. Set up alerts for anomalous patterns (high-frequency tool calls, unusual commands). 5. Retain logs for compliance (90 days minimum).

Remediation Checklist

Prioritized by severity. Address CRITICAL items first.

Quick Win

`npm install mcp-secure`
Adds cryptographic passports, signed messages, tool verification, and audit logging.

CRITICAL (2)

- ☐ **AS-001: unsafe execution**
Replace `exec()/eval()` with AST-parsed execution (`ast.literal_eval` for data, `RestrictedPython` for code).
- ☐ **AS-005: injection pattern**
Validate and sanitize all inputs with strict allowlists.

HIGH (5)

- ☐ **AS-008: excessive agency**
Implement mandatory human-in-the-loop for destructive operations (`delete`, `write`, `execute`, `send`).
- ☐ **AS-006: sandboxing**
Run all agent-generated code in Docker containers with `--network=none` and read-only filesystem.
- ☐ **AS-004: prompt injection**
Sanitize all file contents before injecting into prompts (strip control chars, limit length).
- ☐ **AS-011: data exfiltration**
Implement URL allowlisting — agents can only make HTTP requests to pre-approved domains.
- ☐ **AS-002: secret scan**
Move all secrets to environment variables or a vault (HashiCorp Vault, AWS Secrets Manager, dotenv).

MEDIUM (2)

- ☐ **AS-010: logging monitoring**
Add structured logging (JSON) for every agent action, tool call, and decision.
- ☐ **AS-003: excessive permissions**
Apply principle of least privilege — grant only permissions the agent needs for its specific task.

LOW (1)

- ☐ **AS-007: supply chain**
Use lockfiles (`package-lock.json`, `poetry.lock`, `requirements.txt` with hashes).

Methodology & Standards

Scanner	mcps-audit v1.0.0
Rules Version	1.1.0
Scanned At	02/06/2026, 09:41:54
Report ID	MCPS-MPW17HBK

Referenced Standards

- OWASP MCP Top 10**
Security risks for Model Context Protocol servers and clients.
owasp.org/www-project-mcp-top-10
- OWASP Agentic AI Top 10**
Security risks for autonomous AI agents.
owasp.org/www-project-agentic-ai-top-10
- MCPS -- IETF Internet-Draft**
Cryptographic security layer for MCP: draft-sharif-mcps-secure-mcp.
datatracker.ietf.org/doc/draft-sharif-mcps-secure-mcp
- MITRE ATT&CK**
Adversary tactics and techniques knowledge base.
attack.mitre.org
- STRIDE Threat Model**
Microsoft threat classification framework.
microsoft.com/en-us/security/blog/stride

AgentSign
Cryptographic identity and security for AI agents
agentsign.dev